Center for Internet Security®

CIS Benchmarks™

CIS Microsoft Azure Database Services Benchmark

v2.0.0 - 12-31-2025

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is ***NEVER*** acceptable to host a CIS Benchmark in ***ANY*** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use *1*
Table of Contents *2*
Overview *6*
Important Usage Information 6
Key Stakeholders 6
Apply the Correct Version of a Benchmark 7
Exceptions 7
Remediation 8
Summary 8
Target Technology Details 9
Intended Audience 9
Consensus Guidance 10
Typographical Conventions 11
Recommendation Definitions *12*
Title 12
Assessment Status 12
Automated 12
Manual 12
Profile 12
Description 12
Rationale Statement 12
Impact Statement 13
Audit Procedure 13
Remediation Procedure 13
Default Value 13
References 13
CIS Critical Security Controls® (CIS Controls®) 13
Additional Information 13
Profile Definitions 14
Acknowledgements 15
Recommendations *16*
1 Introduction 16
1.1 CIS Microsoft Azure Foundations Benchmarks 17
1.2 CIS Microsoft Azure Service Category Benchmarks 18
1.3 Multiple Methods of Audit and Remediation 19
1.4 Automating with Azure Policy 21

2 Azure Cache for Redis (Retiring) 23
2.1 Ensure 'Microsoft Entra Authentication' is 'Enabled' (Manual) 24
2.2 Ensure that 'Allow access only via SSL' is set to 'Yes' (Automated) 26
2.3 Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher) (Manual) 28
2.4 Ensure that 'Access Policies' are Implemented and Reviewed Periodically (Manual) 30
2.5 Ensure that 'System Assigned Managed Identity' is set to 'On' (Manual) 32
2.6 Ensure that 'Public Network Access' is 'Disabled' (Manual) 34
2.7 Ensure Azure Cache for Redis is Using a Private Link (Manual) 37
2.8 Ensure that Azure Cache for Redis is Using Customer-Managed Keys (Manual) 41
2.9 Ensure 'Access Keys Authentication' is set to 'Disabled' (Automated) 44
2.10 Ensure 'Update Channel' is set to 'Stable' (Automated) 47

3 Azure Cosmos DB 50
3.1 Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks (Automated) 51
3.2 Ensure that Cosmos DB uses Private Endpoints where possible (Automated) 54
3.3 Ensure that 'disableLocalAuth' is set to 'true' (Automated) 57
3.4 Ensure `Public Network Access` is `Disabled` (Manual) 60
3.5 Ensure critical data is encrypted with customer-managed keys (CMK) (Manual) 63
3.6 Ensure the firewall does not allow all network traffic (Automated) 66
3.7 Ensure that Cosmos DB Logging is Enabled (Manual) 69

4 Azure Data Factory 73
4.1 Ensure Data Factory is encrypted using Customer Managed Keys (Manual) 74
4.2 Ensure Data Factory is using Managed Identities (Automated) 77
4.3 Ensure that Data Factory is using Azure Key Vault to store Credentials and Secrets (Manual) 79
4.4 Ensure that Data Factory is using RBAC to manage privilege assignment (Manual) 82

5 Azure Database for MySQL 84
5.1 Ensure Azure Database for MySQL uses Customer Managed Keys for Encryption at Rest (Manual) 85
5.2 Ensure Azure Database for MySQL uses only Microsoft Entra Authentication (Automated) 87
5.3 Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL (Automated) 89
5.4 Ensure Private Endpoints Are Used for Azure MySQL Databases (Automated) 91
5.5 Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server (Automated) 93
5.6 Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server (Automated) 96
5.7 Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server (Manual) 99
5.8 Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server (Automated) 101
5.9 Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server (Automated) 103

6 Azure Database for PostgreSQL 106
6.1 Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest (Manual) 107
6.2 Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication (Manual) 110
6.3 Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL (Automated) 112
6.4 Ensure Private Endpoints Are Used for Azure Database for PostgreSQL (Automated) 115

6.5 Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server (Automated) 117
6.6 Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server (Automated) 120
6.7 Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server (Automated) 123
6.8 Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers (Automated) 126
6.9 Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers (Automated) 129
6.10 Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server (Automated) 132
6.11 Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server (Automated) 135

7 Azure Database Migration Service 139

8 Azure SQL (Reference) 140

9 Azure SQL Database 141

9.1 Ensure that 'Auditing' is set to 'On' (Automated) 142
9.2 Ensure that 'Public Network Access' is set to 'Disable' (Automated) 146
9.3 Ensure no Azure SQL Database firewall rule is overly permissive (Automated) 149
9.4 Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key (Automated) 153
9.5 Ensure that Microsoft Entra authentication is Configured for SQL Servers (Automated) 158
9.6 Ensure that 'Data encryption' is set to 'On' on a SQL Database (Automated) 162
9.7 Ensure that 'Auditing' Retention is 'greater than 90 days' (Automated) 165
9.8 Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher (Automated) 168

10 Azure SQL Managed Instance 171

11 SQL Server on Azure Virtual Machines 172

12 Table Storage (Reference) 173

13 Azure Managed Instance for Apache Cassandra 174

14 Azure Confidential Ledger (Reference) 175

Appendix: Summary Table 176

Appendix: CIS Controls v7 IG 1 Mapped Recommendations 181

Appendix: CIS Controls v7 IG 2 Mapped Recommendations 183

Appendix: CIS Controls v7 IG 3 Mapped Recommendations 186

Appendix: CIS Controls v7 Unmapped Recommendations 189

Appendix: CIS Controls v8 IG 1 Mapped Recommendations 190

Appendix: CIS Controls v8 IG 2 Mapped Recommendations 192

Appendix: CIS Controls v8 IG 3 Mapped Recommendations 195

Appendix: CIS Controls v8 Unmapped Recommendations 198

Appendix: Change History 199

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the CIS Website. They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- CIS Configuration Assessment Tool (CIS-CAT® Pro Assessor)
- CIS Benchmarks™ Certified 3rd Party Tooling

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that ***ALL*** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.

- **Use the most recent version of a Benchmark**: This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed Build Kits for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
  - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
  - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
  - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
  - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
  - When the initial deployment above is completes successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the CIS Website. All other formats of the CIS Benchmarks™ (MS Word, Excel, and Build Kits) are available for CIS SecureSuite® members.

CIS-CAT® Pro is also available to CIS SecureSuite® members.

Target Technology Details

This benchmark - CIS Microsoft Azure Database Services Benchmark - will provide secure configuration recommendations for Azure products that Microsoft has categorized as “Database” services in the Azure Products Directory (https://azure.microsoft.com/en-us/products#databases).

NOTE: There are other Database services that can be hosted in Azure (e.g. Oracle Database) which are not a part of the Azure Products Directory. For these third-party database services, there may be CIS Communities in WorkBench with specific Benchmark coverage for the third-party database. Those communities can be found by searching here: https://workbench.cisecurity.org/communities

The specific Microsoft Azure services in scope of this Benchmark include:

- Azure Cache for Redis
- Azure Cosmos DB
- Azure Data Factory
- Azure Database for MySQL
- Azure Database for PostgreSQL
- Azure Database Migration Service
- Azure SQL (Reference)
- Azure SQL Database
- Azure SQL Managed Instance
- SQL Server on Azure Virtual Machines
- Table Storage (Reference)
- Azure Managed Instance for Apache Cassandra
- Azure Confidential Ledger (Reference)

For more information on Microsoft Azure product categories and services, please refer to the Microsoft Azure Product Directory here: https://azure.microsoft.com/en-us/products/.

To obtain the latest version of this guide, please visit https://benchmarks.cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at BenchmarkInfo@cisecurity.org.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft Azure.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
`<Monospace font in brackets>`	Text set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like **Notes**, **Warnings**, or **Cautions** (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) “5.1 - Establish Secure Configurations” and (v8) '4.1 - Establish and Maintain a Secure Configuration Process” so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

  Items in this profile intend to:

  - be practical and prudent;
  - provide security focused best practice hardening of a technology; and
  - limit impact to the utility of the technology beyond acceptable means.

- **Level 2**

  This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

  - are intended for environments or use cases where security is more critical than manageability and usability
  - acts as defense in depth measure
  - may impact the utility or performance of the technology

    may include additional licensing, cost, or addition of third party software

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor
Krishna Rayavaram
Steve Johnson
Robert Burton
Steinar Andersen
Michael Born
Rogier Carper

Editor
Logan McMillan
Ian McRee
Rachel Rice

Recommendations

1 Introduction

This introduction section and the subsections herein provide informative articles which instruct on the use of the CIS Foundations and Service Category Benchmarks. No recommendations will be found in this section, just articles of relevant information.

Please carefully review the articles in this introductory section and orient yourself with our structured approach to Benchmarking for Cloud Service Providers (CSPs). This approach differs from other CIS Benchmarks because:

- there are too many different products/services in CSP product directories to practically cover in any one Benchmark,
- architectural and design decisions will affect the scope and relevance of recommendations, and
- there are a variety of methods for interfacing with CSP products and services.

Cloud Benchmarks - A Two-Step Approach to Securing Your Cloud Environments:

- **Step 1:** Start with Foundations Benchmarks. Apply as many recommendations as **practical** for your environment; "100%" 'compliance' is not always possible. Not all Foundations Benchmark recommendations can be applied at the same time, and not all recommendations will be relevant to your environment. Use the recommendation Profile Levels and your understanding of your unique environment architecture to determine which recommendations are in scope.
- **Step 2:** Use the Service Category Benchmarks for service-specific defense-in-depth recommendations. Apply recommendations only for the services **IN USE** in your environment. Use the recommendation Profile Levels, and your understanding of your unique environment architecture to determine which recommendations are in scope.

1.1 CIS Microsoft Azure Foundations Benchmarks

The suggested approach for securing your Microsoft Azure cloud environment is to start with the **latest version** of the CIS Microsoft Azure Foundations Benchmark. Because CSP environments are constantly changing, previous versions of the Foundations Benchmarks should not be used. Previous releases may contain incorrect product names, outdated procedures, deprecated features, and other inaccuracies. The CIS Foundations Benchmark provides prescriptive guidance for configuring a subset of Microsoft Azure Services with an emphasis on foundational, testable, and architecture agnostic settings for services.

The Microsoft Azure Foundations Benchmark is what you should start with when beginning to secure your Azure environment. It is also the foundation for which all other Azure Service Category Benchmarks are built on so that as you grow your cloud presence and usage of the services offered you have the necessary guidance to securely configure your environment as it fits with your company's policy.

All CIS Benchmarks are created and maintained through consensus-based collaboration. Should you have feedback, suggested changes, or just like to get involved in the continued maintenance and development of CIS Microsoft Azure Benchmarks, please register on CIS WorkBench at https://workbench.cisecurity.org and join the CIS Microsoft Azure Benchmarks Community.

1.2 CIS Microsoft Azure Service Category Benchmarks

After configuring your environment with the CIS Microsoft Azure Foundations Benchmark, we suggest pursuing defense-in-depth and service-specific recommendations for your Azure Services by reviewing the Service Category Benchmarks. The Service Category Benchmarks are being produced with the vision that recommendations for all security-relevant products/services offered by a CSP should have a 'home,' but the Foundations Benchmarks should retain the most crucial recommendations and not be made vast, intimidating, and impractical.

The Service Category Benchmark recommendations should be applied **ONLY** for the CSP products and services that are actively **IN USE** in your environment. In each Service Category Benchmark, you may find that your environment uses none, or only a couple services from a list of many. Please review the services employed in your environment carefully to accurately scope the recommendations you apply. Failure to apply only the recommendations you need may introduce vulnerabilities, technical debt, and unnecessary expenses.

Using the Microsoft Azure Product Directory (https://azure.microsoft.com/en-us/products/) as a source of categorical grouping of these services, our vision is to produce a full set of CIS Microsoft Azure Service Category Benchmarks to cover all security-relevant services. A list of planned and published Service Category Benchmarks for the Azure Community can be found on the community dashboard here: https://workbench.cisecurity.org/communities/72.

Your help is needed to bring this vision to life! Please consider joining our CIS Microsoft Azure Community to contribute your expertise and knowledge in securing products and services from the Microsoft Azure product family.

All CIS Benchmarks are created and maintained through consensus-based collaboration. Should you have feedback, suggested changes, or just like to get involved in the continued maintenance and development of CIS Microsoft Azure Benchmarks, please register on CIS WorkBench at https://workbench.cisecurity.org and join the CIS Microsoft Azure Benchmarks community.

1.3 Multiple Methods of Audit and Remediation

Throughout the Benchmark, Audit and Remediation procedures are prescribed using up to five different methods. These multiple methods are presented for the convenience of readers who will be coming from different technical and experiential backgrounds. To perform any given Audit or Remediation, only one method needs to be performed. Not every method is available for every recommendation, and many that are available are not yet written for every recommendation. The methods presented in the Benchmark are formatted and titled as follows:

- "**From Azure Portal**" - This is the administrative GUI accessed at https://portal.azure.com.
- "**From Azure CLI**" - See additional detail in the next section.
- "**From PowerShell**" - See additional detail in the next section.
- "**From REST API**" - An Application Programming Interface (API) for HTTP operations on service endpoints.
- "**From Azure Policy**" - Azure Policy provides an object-based method of evaluating configuration states and other governance detail. Information for the purpose of automating Azure Policy evaluation can be found in the "Automating with Azure Policy" section below.

Setting Up PowerShell and Azure CLI

In order to use the Azure Command Line Interface (CLI) and the Azure PowerShell methods for audit and remediation procedures, the following permissions are required for the account running the procedures:

1. Global Reader
2. Security Reader
3. Subscription Contributor
4. Key Vault Get/List privileges on Keys, Secrets, Certificates, and Certificate Authorities
5. Network allow listing for any source IP address performing the audit activities
6. Permissions to use PowerShell and Azure CLI

These permissions can be directly assigned or assigned via Privileged Identity Management.

The Azure CLI tool can be installed from the following location:
https://docs.microsoft.com/en-us/cli/azure/install-azure-cli-windows?tabs=azure-cli

For PowerShell, the following cmdlets are required:

1. Azure PowerShell: https://learn.microsoft.com/en-us/powershell/azure/install-azure-powershell?view=azps-15.0.0
2. Microsoft Graph PowerShell: https://learn.microsoft.com/en-us/powershell/microsoftgraph/installation?view=graph-powershell-1.0

Authenticating with Azure CLI

Run the following command from either PowerShell or command prompt:

```
az login --tenant <tenant id> --subscription <subscription ID>
```

Authenticating with PowerShell

Login to the Azure tenant and subscription using the following command:

```
Connect-AzAccount
```

If you receive a message indicating `InteractiveBrowserCredential authentication failed`, disable web account manager (WAM) to force a browser authentication with the following command:

```
Update-AzConfig -EnableLoginByWam $false
```

Then attempt using 'Connect-AzAccount' again.

If the browser-based login is not available, you may need to use device-code authentication, but this should be avoided and is not recommended because it is a persistent authentication method and specifically blocked by recommendations found in the Azure Benchmarks. Instructions for this method will not be provided as it is not recommended.

For the Graph PowerShell module, the log in method is the same.

```
Connect-MgGraph
```

1.4 Automating with Azure Policy

Azure Policy provides built-in objects ("Policy Definitions") and a platform for "Policy as Code" that can be used to evaluate and/or enforce configuration states for individual resources or groups of resources. Where a relevant Azure Policy Definition or multiple Policy Definitions have been identified as applicable to a recommendation in this Benchmark, the Policy ID(s) and associated Policy Name will be listed in the "From Azure Policy" method header.

Interfacing with Azure Policy can be performed through the Azure Portal, Azure CLI, Azure PowerShell, REST API, Azure Resource Manager, Bicep, Terraform, or using GitHub Actions. Azure Policy Definitions can be batched together and structured using an "Initiative Definition" (aka: "Initiative" or "Compliance Initiative" or "Policy Set") which is constructed in a JSON file. Scoping and filtering an Azure Policy Initiative is necessary to ensure that the query is relevant to the architecture and requirements of an organization.

Microsoft provides some pre-built Initiative Definitions as a starting point intended to assist in achieving governance and compliance objectives - from Security Frameworks to CIS Benchmarks. These pre-built Initiative Definitions provide a structured set of Policy Definitions with additional metadata to evaluate resource states and configurations, then present the results in an easily readable format. While the Initiatives are a very valuable starting point, they will likely require additional attention for your specific environment, so it is a valuable investment in time to understand how to interact with them to create, remove, update, and delete policy definitions and modify enforcement effects. With some effort and care, policies within an initiative which start by default in an "audit" or "auditIfNotExists" effect can be matured into enforcement effects of "deny," "modify," or "deployIfNotExists" but each individual Policy Definition should be well understood before modifying the effect. In environments that have an advanced posture and custom policy needs, custom Policy Definitions can be created for specialized resource evaluations.

Building an Initiative Definition that fits the needs of your organization is generally a great way to improve overall security posture and has the potential to bring and keep your organization closer to compliance and best practice standards.

NOTE On Outdated Policy Initiatives of CIS Benchmarks:

CIS is aware that outdated versions of the CIS Benchmark are made available through the built-in Policy Initiatives offered in Azure. We always recommend using only the **latest available version** of the CIS Microsoft Azure Foundations Benchmark at all times and **using the latest published version of this Benchmark to update and maintain the policy initiative in your environments**. Cloud service provider environments are in a constant state of change, so best practice guidance - including Azure Policy recommendations - is also in a constant state of reconsideration and possible change.

General references for Azure Policy:

- Microsoft Learn - General Azure Policy Documentation: https://learn.microsoft.com/en-us/azure/governance/policy/
- Designing Policy as Code workflows: https://learn.microsoft.com/en-us/azure/governance/policy/concepts/policy-as-code
- Retrieving Azure Policy information: https://learn.microsoft.com/en-us/azure/governance/policy/how-to/get-compliance-data
- AzPolicyAdvertizer - a very well curated database of Azure Policy Definitions, Initiatives, and related material: https://www.azadvertizer.net/azpolicyadvertizer_all.html

Azure Policy GUI

- The Azure Policy GUI interface can be found in the Azure Admin Portal - simply search for `Policy` and select the Policy service.

Azure Policy from Azure CLI

- Azure CLI commands: https://learn.microsoft.com/en-us/cli/azure/policy?view=azure-cli-latest

Azure Policy from PowerShell

- PowerShell commands: https://learn.microsoft.com/en-us/powershell/module/az.resources#policy

Azure Policy from REST API

- REST API reference: https://learn.microsoft.com/en-us/rest/api/policy/

Azure Policy from GitHub Actions

- Azure Policy GitHub Actions: https://github.com/marketplace/actions/azure-policy-compliance-scan

Azure Policy from Terraform

- Provider: azurerm
- Reference: https://registry.terraform.io/providers/hashicorp/azurerm/latest/docs/resources/policy_definition

2 Azure Cache for Redis (Retiring)

IMPORTANT NOTE: Azure Cache for Redis (Basic, Standard, Premium) and Azure Cache for Redis Enterprise/Enterprise Flash tiers are on a retirement path.

- Azure Cache for Redis (Basic, Standard, Premium) Retirement Date: September 30, 2028
- Azure Cache for Redis Enterprise/Enterprise Flash tiers Retirement Date: March 31, 2027

Microsoft recommends migrating to Azure Managed Redis. Please review Microsoft's announcement on this service retirement here: https://techcommunity.microsoft.com/blog/azure-managed-redis/azure-cache-for-redis-retirement-what-to-know-and-how-to-prepare/4458721

This section covers security best practice recommendations for Azure Cache for Redis.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Cache for Redis

Azure Product Page:

- https://azure.microsoft.com/en-us/products/cache/

Azure Cache for Redis service overview:

- https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/

Microsoft Cloud Security Baseline for Azure Cache for Redis:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-cache-for-redis-security-baseline

2.1 Ensure 'Microsoft Entra Authentication' is 'Enabled' (Manual)

Profile Applicability:

- Level 1

Description:

Ensuring that Microsoft Entra Authentication is ‘Enabled’ provides a natively integrated use of identities already defined with Microsoft Entra ID.

Rationale:

The use of a centralized Identity and Access Management (IAM) solution such as Microsoft Entra ID is highly recommended for all activity related to Identity, Authentication, Authorization, and Accountability.

Decentralized IAM – such as local authentication methods – may present additional vulnerability and introduce avoidable administrative complexity.

Impact:

Free tiers exist for the licensing of Microsoft Entra ID if required.

Audit:

Audit From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, click on `Authentication`
5. Review the checkbox next to `Enable Microsoft Entra Authentication`

If the checkbox is `Checked`, the configuration for that instance is compliant.

Remediation:

Remediate From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, click on `Authentication`
5. `Check` the checkbox next to `Enable Microsoft Entra Authentication`

Default Value:

By default, Microsoft Entra Authentication is `Checked` during setup.

References:

1. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-identity-management
2. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-azure-active-directory-for-authentication

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 Centralize Account Management Centralize account management through a directory or identity service.		●	●
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

2.2 Ensure that 'Allow access only via SSL' is set to 'Yes' (Automated)

Profile Applicability:

- Level 1

Description:

Setting ‘Allow access only via SSL’ to ‘Yes’ ensures that data in transit to and from Azure Cache for Redis is encrypted using TLS.

Rationale:

Data in transit which is not encrypted is vulnerable to attacks including adversary-in-the-middle (AITM or MITM), eavesdropping, or session hijack. These attacks can result in the compromise and exfiltration of data.

Impact:

No additional cost is required to implement this recommendation. Aside from expected network changes (no unencrypted communications), performance should not be impacted.

Audit:

Audit From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Advanced Settings`
5. Review the setting under `Allow access only via SSL`

If `Yes` is selected, the configuration for that instance is compliant.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 22bee202-a82f-4305-9a2a-6d7f44d4dedb **- Name:** 'Only secure connections to your Azure Cache for Redis should be enabled'
- **Policy ID:** 766f5de3-c6c0-4327-9f4d-042ab8ae846c **- Name:** 'Configure Azure Cache for Redis to disable non SSL ports'

Remediation:

Remediate From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Advanced Settings`
5. Select `Yes` under the `Allow access only via SSL` heading

Default Value:

By default, 'Allow access only via SSL' is set to 'Yes.'

References:

1. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-best-practices-development
2. https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-cache-for-redis-security-baseline#microsoft-defender-for-cloud-monitoring-1

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

2.3 Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher) (Manual)

Profile Applicability:

- Level 1

Description:

Setting the 'Minimum TLS version' helps reduce (but not eliminate) TLS protocol vulnerabilities by preventing the use of significantly outdated versions of TLS.

Rationale:

The Secure Sockets Layer (SSL) protocol encrypts network traffic transiting between server and client.

Using only the most recent versions of SSL protocols (TLS version 1.2 and higher) eliminates susceptibility to known exploited vulnerabilities of outdated versions of TLS. If TLS 1.2 does not provide additional granular configuration options for supported cipher suites, there's a chance that default ciphers which employ Cipher Block Chaining (CBC) mode may be enabled which would introduce Padding Oracle types of vulnerabilities. TLS 1.3 does not support CBC mode ciphers by default and by default supports GCM ciphers which include an extra authentication step during the clear text to cipher text encryption process.

TLS version 1.3 is preferable where it is possible to implement.

Versions 1.0 and 1.1 of TLS are no longer considered secure. These versions should not be used or permitted where data integrity and confidentiality are required.

Impact:

This configuration setting should not result in any perceptible changes to cost or performance.

Audit:

Audit From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance listed, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Advanced Settings`
5. Review the setting under `Minimum TLS version`

If `1.2 (Recommended)` (or a higher version) is selected, the configuration for that instance is compliant.

Remediation:

Remediate From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance listed, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Advanced Settings`
5. Click the drop-down menu under `Minimum TLS version`
6. Select `1.2 (Recommended)` (higher versions are preferred when available)

References:

1. https://www.rfc-editor.org/rfc/pdfrfc/rfc8446.txt.pdf
2. https://nvd.nist.gov/vuln/detail/CVE-2016-0701

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

2.4 Ensure that 'Access Policies' are Implemented and Reviewed Periodically (Manual)

Profile Applicability:

- Level 2

Description:

Access Policies provide an Access Control List (ACL) functionality allowing administrators to define which identities or identity groups have access to what data and commands. This is an implementation of the Role Based Access Control (RBAC) concept and will require careful consideration to deploy and maintain.

Rationale:

Role Based Access Control (RBAC) using Access Control Lists (ACLs) is a method of implementing the principle of least privilege by ensuring that users and user groups with differing needs are presented with the privilege that fulfills their needs and any unnecessary access or functionality is prevented.

Impact:

Implementing RBAC for any system requires a careful analysis of 'who' needs access to the system, and 'what' privileges or functionality they need to perform. The time required to implement RBAC will increase based on the complexity and size of an environment.

If RBAC is deployed without careful analysis, it may prevent users from accessing data or functionality that they require from the system. Conversely, it may present privilege which is unnecessary and introduce vulnerability to a system.

Once RBAC has been deployed, there should be periodically scheduled access review. During the access review, all entries in the Access Control List and all identities are reviewed for fitness and necessity.

Audit:

Audit From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Data Access Configuration`
5. Click on the tab titled `Access Policies` and review the access policies for fitness and necessity.

Please note: No more specific definition can be presented here because the definitions of fitness and necessity are judgments that must be made by the administrators and security personnel with knowledge of the identities and functionality required of the system being evaluated.

Remediation:

No prescriptive remediation is available due to the specific and unique nature of implementing RBAC for any given system. Implementing RBAC for any system requires a careful analysis of 'who' needs access to the system, and 'what' privileges or functionality they require. The time required to implement RBAC will increase based on the complexity and size of an environment.

Default Value:

By default, no Access Policies exist.

References:

1. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-configure-role-based-access-control

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14.7 Enforce Access Control to Data through Automated Tools Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when data is copied off a system.			●

2.5 Ensure that 'System Assigned Managed Identity' is set to 'On' (Manual)

Profile Applicability:

- Level 1

Description:

System Assigned Managed Identities provide the Azure Cache for Redis instance with a unique account like a service principle but automatically assigned and managed by Azure. These identities are unique to the resource instance they are created for, and removed when the resource is deleted.

Rationale:

The System Assigned Managed Identity is authenticated with Entra ID, and allows for privileges required for the instance of Azure Cache for Redis to be granted or restricted using Azure Role Based Access Control (RBAC). Additionally, the managed identity provides a means for the Azure Cache for Redis instance to authenticate without storing credentials in code.

Audit:

Audit From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Identity`
5. Under the `System assigned` tab, ensure that `Status` is set to `On.`

If `Yes` is selected and `Object (principal) ID` is populated, the configuration for that instance is compliant.

Remediation:

Remediate From Azure Portal

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, under Settings, click on `Identity`
5. Under the `System assigned` tab, toggle the status to `On`
6. Click the `Save` button
7. In the pop-up dialog titled `Enable system assigned managed identity` that appears after clicking save, click the `Yes` button.

Default Value:

By default, System Assigned Managed Identity of `Off`.

References:

1. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-managed-identity

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.5 Establish and Maintain an Inventory of Service Accounts Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.		●	●

2.6 Ensure that 'Public Network Access' is 'Disabled' (Manual)

Profile Applicability:

- Level 2

Description:

Disabling public network access restricts the service from accessing public networks.

Rationale:

A secure network architecture requires carefully constructed network segmentation. Public Network Access tends to be overly permissive and introduces unintended vectors for threat activity.

Impact:

Disabling 'Public Network Access' forces the requirement of the use of Private Endpoints for network connectivity which will require some additional consideration from a network architecture perspective and will introduce cost based on the inbound/outbound data being processed by the Private Endpoint.

IMPORTANT NOTE: If Azure Cache for Redis has been deployed in a VNet, this recommendation cannot be implemented. See additional information below for more detail.

Audit:

Audit From Azure Portal

NOTE: This procedure applies only to instances that are not using VNets.

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, click on `Private Endpoint`
5. Review the button to the right of `+ Private Endpoint`

If the button is titled `enable public network access`, the configuration for that instance is currently disabled and compliant.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 470baccb-7e51-4549-8b1a-3e5be069f663 **- Name:** 'Azure Cache for Redis should disable public network access'

Remediation:

Remediate From Azure Portal

NOTE: A Private Endpoint must exist before the “Disable public network access” button allows the configuration change to be performed via Portal.

1. Search for and open the `Azure Cache for Redis` service
2. For each instance, repeat the remaining steps
3. Click on the name of the instance
4. In the blade menu on the left, click on `Private Endpoint`
5. Click the `Disable public network access` button.

Default Value:

By default Public Network Access is `Disabled` when creating an Azure Cache for Redis instance.

References:

1. https://learn.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-network-security#ns-2-secure-cloud-services-with-network-controls
2. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-network-isolation
3. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-private-link#how-can-i-change-my-private-endpoint-to-be-disabled-or-enabled-from-public-network-access

Additional Information:

For Azure Cache for Redis instances deployed in classic VNets (Virtual Network injection), public network access cannot be disabled. In these cases, an equivalent control using restrictive Access Control Lists (ACLs) in Network Security Groups (NSGs) and/or Azure Firewall is recommended. If it is feasible, the Azure Cache for Redis instance can also be deleted and re-created with a new instance using Private Endpoints instead of VNets.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

2.7 Ensure Azure Cache for Redis is Using a Private Link (Manual)

Profile Applicability:

- Level 2

Description:

Private links make resources available via a private endpoint to a network you select. Tunneling between subscriptions, resource groups, without the need for traditional network routing.

Rationale:

Networking communication should be segmented to prevent undesired interception.

Impact:

If improperly configured network communication between your Azure Cache for Redis and other resources may be interrupted. This is only concerning resources or services being offered to other Azure tenants.

Audit:

Audit From Azure Portal

1. Go to `Azure Cache for Redis`.
2. Select the name of a cache.
3. Expand the `Administration` menu in the left column.
4. Select `Networking`.
5. View the private endpoints associated with the cache.

Audit From PowerShell

1. Run the following code block with the identifying information for your environment.

```
Get-AzPrivateEndpoint-ResourceGroupName <ResourceGroupName> |
Where-Object{
$_.PrivateLinkServiceConnections.PrivateLinkServiceId -eq
<AzureCacheforRedisName>
}
```

2. View the private endpoints associated with the cache.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 960e650e-9ce3-4316-9590-8ee2c016ca2f **- Name:** 'Azure Cache for Redis should use private link'

Remediation:

Remediate From Azure Portal

1. Go to `Azure Cache for Redis`.
2. Select the name of a cache.
3. In the left column expand `Administration`.
4. Select `Networking`.
5. In the top heading select `Private Endpoints`.
6. Select `+ Private Endpoint`.
7. Select your subscription and resource group then select `Next : Resource >`.
8. Select `Connect to an Azure resource in my directory.`
9. Enter your subscription id or select from the dropdown.
10. Under Resource type select Microsoft.Cache/redisEnterprise from the dropdown.
11. Select your resource and your sub-resource of `redisEnterprise`.
12. Select your desired virtual network.
13. Select your desired subnet.
14. Determine whether you want to dynamically or statically allocate an IP address.
15. Select your network application security group or select `+ Create` to create a new one, the select `Next`.
16. Determine if you want to create a dns entry in a private DNS zone or on your own DNS servers. If in a private DNS zone select the desired subscription and resource group. Select next.
17. Enter any tags necessary, then click next.
18. Review the settings and select `Create`.
19. After creation your Cache will be available in your network at the FQDN and IP address listed under `Settings` and `DNS configuration`.

Remediate From PowerShell

```
$resourceGroup      = "<resourcegroup>"
$virtualNetName     = "<virtualnetworkname>"
$subnetName         = "<subnetName>"
$redisName          = "<rediscachename>"
$privateEndpointName = "<privateendpointname>"
$dnsZoneName        = "<dnsfqdn>"
$dnsLinkName        = "<redisdnsname>"

# Get existing resources
$vnet  = Get-AzVirtualNetwork -Name $virtualNetName -ResourceGroupName
$resourceGroup
$subnet = Get-AzVirtualNetworkSubnetConfig -VirtualNetwork $virtualNetName -
Name $subnetName
$redis = Get-AzRedisCache -Name $redisName -ResourceGroupName $resourceGroup

# Validate Redis resource ID for Private Endpoint connection
$redisResourceId = $redis.Id

# Link DNS Zone to Virtual Network
$link = New-AzPrivateDnsVirtualNetworkLink `
    -ZoneName $dnsZoneName `
    -ResourceGroupName $resourceGroup `
    -Name $dnsLinkName `
    -VirtualNetworkId $vnet.Id `
    -EnableRegistration false

# Create the Private Endpoint
$privateLinkConnection = New-AzPrivateLinkServiceConnection `
    -Name $privateEndpointName `
    -PrivateLinkServiceId $redisResourceId `
    -GroupId "redisCache"

$privateEndpoint = New-AzPrivateEndpoint `
    -Name $privateEndpointName `
    -ResourceGroupName $resourceGroup `
    -Location $location `
    -Subnet $subnet `
    -PrivateLinkServiceConnection $privateLinkConnection
```

Default Value:

Unless configured at resource creation, by default no private links are used in Azure Cache for Redis.

References:

1. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-private-link
2. https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-cache-for-redis-security-baseline
3. https://learn.microsoft.com/en-us/cli/azure/network/private-endpoint?view=azure-cli-latest

4. https://learn.microsoft.com/en-us/powershell/module/az.network/get-azprivateendpoint?view=azps-14.6.0
5. https://learn.microsoft.com/en-us/azure/private-link/private-link-overview

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	12.2 Establish and Maintain a Secure Network Architecture Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

2.8 Ensure that Azure Cache for Redis is Using Customer-Managed Keys (Manual)

Profile Applicability:

- Level 2

Description:

Customer Managed Keys allow you more granular control over the encryption of your information.

Rationale:

Customer Managed Keys increase security of your disk encryption by offering features like custom managed expiration dates, allowing you to set your own key lifecycle.

Impact:

This comes with an increased cost, as only Enterprise tier Azure Cache for Redis supports customer managed keys.

Audit:

Audit From Azure Portal

1. Select your Redis Cache.
2. In the left column select Encryption.
3. View the keys listed, and determine if the checkbox for 'Customer Managed Key' is selected.

Audit From Powershell

1. Run the following command to determine if your Azure Cache for Redis is using a Customer Managed Key.

```
Get-AzRedisEnterpriseCache -ResourceGroupName "<resourcegroupname>" -Name
"<azurecacheforredisname" | Select-Object -ExpandProperty
EnableCustomerManagedKey
```

2. If the command returns true, you are using a customer managed key.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 09aa11bb-87ec-409f-bf0b-49b7c1561a87 **- Name:** 'Azure Cache for Redis Enterprise should use customer-managed keys for encrypting disk data'

Remediation:

Remediate From Azure Portal

1. Select your Redis Cache.
2. In the left column select Encryption.
3. Select the checkbox to enable Customer Managed keys.
4. Select `Add` to assign a user managed identity with permissions to access your Azure key vault.
5. Select your subscription and Azure Key vault that contains your customer managed key. Ensure this is in the same region as your Azure Cache for Redis.
6. Select your customer managed key.
7. Click `Save`.

Remediate From Powershell

1. In Azure Key Vault find the full URL for a key you have created. Then run the following command with the information for your environment.

```
Update-AzRedisEnterpriseCache -ClusterName "<yourclustername>"
=ResourceGroupName "<yourresourcegroupname>" -
CustomerManagedKeyEncryptionKeyUrl "<thekeyinazurekeyvaultURL>"
```

Default Value:

By default Azure Cache for Redis uses Microsoft Managed Keys for all Redis services.

References:

1. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-how-to-encryption
2. https://learn.microsoft.com/en-us/powershell/module/az.redisenterprisecache/get-azredisenterprisecache
3. https://learn.microsoft.com/en-us/powershell/module/az.redisenterprisecache/update-azredisenterprisecache

Additional Information:

Be certain to set your expiration dates and other settings for the Customer Managed Key within your Azure Key Vault for optimal security.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

2.9 Ensure 'Access Keys Authentication' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1

Description:

Ensure access key authentication is disabled for Azure Cache for Redis instances. Use Microsoft Entra for secure cache authentication.

Rationale:

Access keys introduce security risks and management challenges, as they are long-lived secrets vulnerable to expose or misuse. Microsoft Entra authentication provides centralized identity and access management, reducing risk and improving overall security.

Impact:

Disabling access key authentication terminates all existing client connections. Ensure retry mechanisms are in place for reconnection via Microsoft Entra.

Ensure Microsoft Entra authentication is enabled and configured before disabling access key authentication.

Refer to the recommendation in this section titled **"Ensure 'Microsoft Entra Authentication' is 'Enabled'"** for details.

Audit:

Audit from Azure Portal

1. Go to `Azure Cache for Redis`.
2. Select the name of a cache.
3. Under `Settings`, select `Authentication`.
4. Select `Access keys`.
5. Ensure `Disable Access Keys Authentication` is checked.
6. Repeat steps 1-5 for each cache.

Audit from Azure CLI

Run the following command to list caches:

```
az redis list
```

For each cache, run the following command to get the `disableAccessKeyAuthentication` setting:

```
az redis show --resource-group <resource-group> --name <cache> --query
disableAccessKeyAuthentication
```

Ensure `true` is returned.

Audit from PowerShell

Run the following command to list caches:

```
Get-AzRedisCache
```

Run the following command to get the cache in a resource group with a given name:

```
$cache = Get-AzRedisCache -ResourceGroupName <resource-group> -Name <cache>
```

Run the following command to get the `DisableAccessKeyAuthentication` setting:

```
$cache.DisableAccessKeyAuthentication
```

Ensure `True` is returned.

Repeat for each cache.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 3827af20-8f80-4b15-8300-6db0873ec901 **- Name:** 'Azure Cache for Redis should not use access keys for authentication'

Remediation:

Remediate from Azure Portal

1. Go to `Azure Cache for Redis`.
2. Select the name of a cache.
3. Under `Settings`, select `Authentication`.
4. Select `Access keys`.
5. Check `Disable Access Keys Authentication`.
6. Select `Save`.
7. Select `Yes` to confirm.
8. Repeat steps 1-7 for each cache.

Remediate from Azure CLI

For each cache requiring remediation, run the following command to disable access key authentication:

```
az redis update --resource-group <resource-group> --name <cache> --set
"disableAccessKeyAuthentication=true"
```

Remediate from PowerShell

For each cache requiring remediation, run the following command to disable access key authentication:

```
Set-AzRedisCache -ResourceGroupName <resource-group> -Name <cache> -
DisableAccessKeyAuthentication $true
```

Default Value:

By default, access key authentication is disabled.

References:

1. https://learn.microsoft.com/en-gb/azure/azure-cache-for-redis/cache-azure-active-directory-for-authentication

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 Centralize Account Management Centralize account management through a directory or identity service.		●	●
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1134	TA0004	M1018

2.10 Ensure 'Update Channel' is set to 'Stable' (Automated)

Profile Applicability:

- Level 1

Description:

Ensure all Azure Cache for Redis instances are configured to use the stable update channel.

Rationale:

By using the stable update channel, organizations minimize the risk of introducing issues that may exist in preview update streams. The stable update channel improves security posture and reduces exposure to vulnerabilities.

Impact:

Updates and new features will take longer to arrive when using the stable update channel.

Audit:

Audit from Azure Portal

1. Go to `Azure Cache for Redis`.
2. Select the name of a cache.
3. Under `Settings`, select `Schedule updates`.
4. Ensure `Update Channel` is set to `Stable`.
5. Repeat steps 1-4 for each cache.

Audit from Azure CLI

Run the following command to list caches:

```
az redis list
```

For each cache, run the following command to get the `updateChannel` setting:

```
az redis show --resource-group <resource-group> --name <cache> --query
updateChannel
```

Ensure `"Stable"` is returned.

Audit from PowerShell

Run the following command to list caches:

```
Get-AzRedisCache
```

Run the following command to get the cache in a resource group with a given name:

```
$cache = Get-AzRedisCache -ResourceGroupName <resource-group> -Name <cache>
```

Run the following command to get the `UpdateChannel` setting:

```
$cache.UpdateChannel
```

Ensure `Stable` is returned.

Repeat for each cache.

Remediation:

Remediate from Azure Portal

1. Go to `Azure Cache for Redis`.
2. Select the name of a cache.
3. Under `Settings`, select `Schedule updates`.
4. Set `Update Channel` to `Stable`.
5. Select `Save`.
6. Repeat steps 1-5 for each cache requiring remediation.

Remediate from Azure CLI

For each cache requiring remediation, run the following command to set `updateChannel` to `Stable`:

```
az redis update --resource-group <resource-group> --name <cache> --set
"updateChannel=Stable"
```

Remediate from PowerShell

For each cache requiring remediation, run the following command to set `UpdateChannel` to `Stable`:

```
Set-AzRedisCache -ResourceGroupName <resource-group> -Name <cache> -
UpdateChannel Stable
```

Default Value:

By default, 'Update Channel' is set to 'Stable'.

References:

1. https://learn.microsoft.com/en-us/azure/azure-cache-for-redis/cache-administration#update-channel-and-schedule-updates

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.2 Ensure Authorized Software is Currently Supported Ensure that only currently supported software is designated as authorized in the software inventory for enterprise assets. If software is unsupported, yet necessary for the fulfillment of the enterprise's mission, document an exception detailing mitigating controls and residual risk acceptance. For any unsupported software without an exception documentation, designate as unauthorized. Review the software list to verify software support at least monthly, or more frequently.	●	●	●
v7	2.2 Ensure Software is Supported by Vendor Ensure that only software applications or operating systems currently supported by the software's vendor are added to the organization's authorized software inventory. Unsupported software should be tagged as unsupported in the inventory system.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1190	TA0001	M1051

3 Azure Cosmos DB

This section covers security best practice recommendations for Azure Cosmos DB.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Cosmos DB

Azure Product Page:

- https://azure.microsoft.com/en-us/products/cosmos-db/

Azure Cosmos DB service overview:

- https://learn.microsoft.com/en-us/azure/cosmos-db/

Microsoft Cloud Security Baseline for Azure Cosmos DB:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-cosmos-db-security-baseline

3.1 Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks (Automated)

Profile Applicability:

- Level 2

Description:

Limiting your Cosmos DB to only communicate on whitelisted networks lowers its attack footprint.

Rationale:

Selecting certain networks for your Cosmos DB to communicate restricts the number of networks including the internet that can interact with what is stored within the database.

Impact:

WARNING: Failure to whitelist the correct networks will result in a connection loss. If using NoSQL / Table / Graph APIs for Cosmos DB Data Explorer end user IPs must be allowed. Other APIs are proxied and shouldn't require end user IPs.

WARNING: Changes to Cosmos DB firewalls may take up to 15 minutes to apply. Ensure that sufficient time is planned for remediation or changes to avoid disruption.

Audit:

Audit From Azure Portal

1. Open the portal menu.
2. Select the Azure Cosmos DB blade
3. Select a Cosmos DB to audit.
4. Select `Networking`.
5. Under `Public network access`, ensure `Selected networks` is selected.
6. Under `Virtual networks`, ensure appropriate virtual networks are configured.

Audit From Azure CLI

Retrieve a list of all CosmosDB database names:

```
az cosmosdb list
```

For each database listed, run the following command:

```
az cosmosdb show <database id>
```

For each database, ensure that `isVirtualNetworkFilterEnabled` is set to `true`

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 862e97cf-49fc-4a5c-9de4-40d4e2e7c8eb **- Name:** 'Azure Cosmos DB accounts should have firewall rules'

Remediation:

Remediate From Azure Portal

1. Open the portal menu.
2. Select the Azure Cosmos DB blade.
3. Select a Cosmos DB account to audit.
4. Select `Networking`.
5. Under `Public network access`, select `Selected networks`.
6. Under `Virtual networks`, select `+ Add existing virtual network` or `+ Add a new virtual network`.
7. For existing networks, select subscription, virtual network, subnet and click `Add`. For new networks, provide a name, update the default values if required, and click `Create`.
8. Click `Save`.

Default Value:

By default, Cosmos DBs are set to have access all networks.

References:

1. https://docs.microsoft.com/en-us/azure/cosmos-db/how-to-configure-private-endpoints
2. https://docs.microsoft.com/en-us/azure/cosmos-db/how-to-configure-vnet-service-endpoint
3. https://docs.microsoft.com/en-us/cli/azure/cosmosdb?view=azure-cli-latest#az-cosmosdb-show
4. https://docs.microsoft.com/en-us/cli/azure/cosmosdb/database?view=azure-cli-latest#az-cosmosdb-database-list
5. https://docs.microsoft.com/en-us/powershell/module/az.cosmosdb/?view=azps-8.1.0
6. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-network-security#ns-2-secure-cloud-native-services-with-network-controls

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	12.2 Establish and Maintain a Secure Network Architecture Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.		●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

3.2 Ensure that Cosmos DB uses Private Endpoints where possible (Automated)

Profile Applicability:

- Level 2

Description:

Private endpoints limit network traffic to approved sources.

Rationale:

For sensitive data, private endpoints allow granular control of which services can communicate with Cosmos DB and ensure that this network traffic is private. This can be set this up on a case by case basis for each service to be connected.

Impact:

Only whitelisted services will have access to communicate with the Cosmos DB.

Audit:

Audit From Azure Portal

1. Open the portal menu.
2. Select the Azure Cosmos DB blade.
3. Select the Azure Cosmos DB account.
4. Select `Networking`.
5. Ensure `Public network access` is set to `Selected networks`.
6. Ensure the listed networks are set appropriately.
7. Select `Private access`.
8. Ensure a private endpoint exists and `Connection state` is `Approved`.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 58440f8a-10c5-4151-bdce-dfbaad4a20b7 **- Name:** 'CosmosDB accounts should use private link'

Remediation:

Remediate From Azure Portal

1. Open the portal menu.
2. Select the Azure Cosmos DB blade.
3. Select the Azure Cosmos DB account.
4. Select `Networking`.
5. Select `Private access`.
6. Click `+ Private Endpoint`.
7. Provide a Name.
8. Click `Next`.
9. From the Resource type drop down, select `Microsoft.AzureCosmosDB/databaseAccounts`.
10. From the Resource drop down, select the Cosmos DB account.
11. Click `Next`.
12. Provide appropriate Virtual Network details.
13. Click `Next`.
14. Provide appropriate DNS details.
15. Click `Next`.
16. Optionally provide Tags.
17. Click `Next : Review + create`.
18. Click `Create`.

Default Value:

By default Cosmos DB does not have private endpoints enabled and its traffic is public to the network.

References:

1. https://docs.microsoft.com/en-us/azure/cosmos-db/how-to-configure-private-endpoints
2. https://docs.microsoft.com/en-us/azure/private-link/tutorial-private-endpoint-cosmosdb-portal
3. https://docs.microsoft.com/en-us/cli/azure/cosmosdb/private-endpoint-connection?view=azure-cli-latest
4. https://docs.microsoft.com/en-us/cli/azure/network/private-endpoint?view=azure-cli-latest#az-network-private-endpoint-create
5. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-network-security#ns-2-secure-cloud-native-services-with-network-controls

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	12.2 Establish and Maintain a Secure Network Architecture Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

3.3 Ensure that 'disableLocalAuth' is set to 'true' (Automated)

Profile Applicability:

- Level 1

Description:

Ensure that key-based authentication (including resource owner password credential authentication) is disabled for Azure Cosmos DB accounts by setting `disableLocalAuth` to `true`. Instead, use Microsoft Entra ID for authentication, as it provides stronger security through managed credentials, multi-factor authentication (MFA), centralized access control, and seamless integration with Azure RBAC.

Rationale:

Disabling key-based authorization ensures that access to your Azure Cosmos DB account relies on the more secure Microsoft Entra ID authentication, reducing the risk of credential misuse and unauthorized access.

Impact:

Administrative overhead in configuring, managing, and monitoring Entra ID authentication and role-based access.

Audit:

Audit from Azure CLI

Run the following command to get the `disableLocalAuth` setting for each Cosmos DB account:

```
az cosmosdb list --query "[].{name:name, resourceGroup:resourceGroup,
disableLocalAuth:disableLocalAuth}"
```

Ensure that `disableLocalAuth` is set to `true` for each Cosmos DB account.

Audit from PowerShell

Run the following command to list Cosmos DB accounts in a resource group:

```
Get-AzCosmosDBAccount -ResourceGroupName <resource-group>
```

Run the following command to get the Cosmos DB account in a resource group with a given name:

```
$cosmosdb = Get-AzResource -ResourceType
Microsoft.DocumentDB/databaseAccounts -ResourceGroupName <resource-group> -
ResourceName <cosmosdb-account>
```

Run the following command to get the `disableLocalAuth` setting for the Cosmos DB account:

```
$cosmosdb.Properties.disableLocalAuth
```

Ensure that the command returns `True`.

Repeat for each Cosmos DB account.

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 5450f5bd-9c72-4390-a9c4-a7aba4edfdd2 **- Name:** 'Cosmos DB database accounts should have local authentication methods disabled'

Remediation:

Map all the resources that currently have access to the Azure Cosmos DB account with keys or access tokens.

Create an Entra ID identity for each of these resources:

- For Azure resources, you can create a managed identity. You may choose between system-assigned and user-assigned managed identities.
- For non-Azure resources, create Entra ID service principals. Grant each Entra ID service principal the minimum permissions it requires. We recommend using one of the two built-in role definitions: Cosmos DB Built-in Data Reader or Cosmos DB Built-in Data Contributor. Validate that the new resource is functioning correctly. After new permissions are granted to identities, it may take a few hours for them to propagate.

When all resources work correctly with the new identities, continue to the next step.

Remediate from Azure CLI

For each Cosmos DB account requiring remediation, run the following command to set `disableLocalAuth` to `true`:

```
az resource update --resource-group <resource-group> --name <cosmosdb-
account> --resource-type Microsoft.DocumentDB/databaseAccounts --set
properties.disableLocalAuth=true
```

Remediate from PowerShell

For each Cosmos DB account requiring remediation, run the following commands to set `disableLocalAuth` to `True`:

```
$cosmosdb = Get-AzResource -ResourceType
Microsoft.DocumentDB/databaseAccounts -ResourceGroupName <resource-group> -
ResourceName <cosmosdb-account>
$cosmosdb.Properties.disableLocalAuth = "True"
$cosmosdb | Set-AzResource -Force
```

Default Value:

By default, `disableLocalAuth` is set to `false`.

References:

1. https://learn.microsoft.com/en-us/azure/cosmos-db/nosql/security/how-to-disable-key-based-authentication
2. https://learn.microsoft.com/en-us/azure/cosmos-db/role-based-access-control

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.		●	●
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1190		

3.4 Ensure `Public Network Access` is `Disabled` (Manual)

Profile Applicability:

- Level 2

Description:

Setting public networks to disabled prevents requests from the public internet.

Rationale:

Allowlisting secures Azure Cosmos DB from the public internet and prevents unauthorized access requests.

Impact:

If improperly configured, network communication to the Azure Cosmos DB Account will be interrupted, including Azure web portal access potentially. Be certain to check the additional resources linked here and allowlist appropriate IPs for your environment before selecting apply.

Disabling 'Public Network Access' forces the requirement of the use of Private Endpoints for network connectivity which will require some additional consideration from a network architecture perspective and will introduce cost based on the inbound/outbound data being processed by the Private Endpoint.

Audit:

Audit from Azure Portal

1. Select or search for `Azure CosmosDB`.
2. Select your Azure CosmosDB Account.
3. In the left column expand `> Settings`.
4. Select `Networking`.
5. Determine in the second row if Public Network Access is set to `All Networks`.

Audit from Powershell

1. Run the following Powershell command with identifying information for your environment.

```
Get-AzCosmosDBAccount -Name <cosmosdbaccountname> -ResourceGroupName
<resourcegroupname> | Select-Object -Property "PublicNetworkAccess",
"IpRules", "IpRangeFilter"
```

2. Determine from left to right, if public network access is enabled, which IpRules are set, and which IP Ranges are allowlisted. All must be accurate for your environment for proper functionality.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 797b37f7-06b8-444c-b1ad-fc62867f335a **- Name:** 'Azure Cosmos DB should disable public network access'

Remediation:

Remediate from Azure Portal

1. Select or search for `Azure CosmosDB`.
2. Select your Azure CosmosDB Account.
3. In the left column expand `> Settings`.
4. Select `Networking`.
5. Under `Public Access` select the radial button `Disabled`.
6. Select `Save`

Remediate from Powershell

1. Run the following Powershell as many times as you need with the public network information for your environment to allowlist your ip addresses with CIDR notation, e.g. `0.0.0.0/0`. These must also not be private IP addresses.

```
Update-AzCosmosDBAccount -name <cosmosdbaccountname> -ResourceGroupName
<resourcegroupname> -IPRule <IPRange>
```

2. Once all your IP addresses are allowlisted, run the following Powershell command with identifying information for your environment.

```
Update-AzCosmosDBAccount -name <cosmosdbaccountname> -ResourceGroupName
<resourcegroupname> -PublicNetworkAccess 'Disabled'
```

Default Value:

Unless specified at resource creation, Azure CosmosDB by default allows public network access, but authenticates requests.

References:

1. https://learn.microsoft.com/en-us/azure/cosmos-db/how-to-configure-firewall
2. https://learn.microsoft.com/en-us/powershell/module/az.cosmosdb/update-azcosmosdbaccount?view=azps-15.0.0#-publicnetworkaccess

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

3.5 Ensure critical data is encrypted with customer-managed keys (CMK) (Manual)

Profile Applicability:

- Level 2

Description:

Customer-managed keys introduce additional depth to security by providing control over encryption keys. Where required, and organizational capacity allows, sensitive data at rest can be encrypted using customer-managed keys.

While it is possible to automate the assessment of this recommendation, the assessment status remains "Manual" due to ideally limited scope. The scope of application should be carefully considered to account for organizational capacity, and targeted to workloads with specific need for CMK.

Rationale:

Customer-managed keys provide greater control over the creation, rotation, and revocation of encryption keys, supporting strict security and compliance requirements.

Impact:

Implementing customer-managed keys introduces additional administrative effort to create, rotate, monitor, and secure encryption keys.

Audit:

Audit from Azure Portal

1. Go to `Azure Cosmos DB`.
2. Select the name of an Azure Cosmos DB account.
3. Under `Settings`, select `Data Encryption`.
4. Ensure `Encryption Key Type` is set to `Customer-managed key`.
5. Repeat steps 1-4 for each account.

Audit from Azure CLI

Run the following command to list Azure Cosmos DB accounts:

```
az cosmosdb list
```

For each account, run the following command to get the Key Vault key URI:

```
az cosmosdb show --resource-group <resource-group> --name <cosmos-db> --query
keyVaultKeyUri
```

Ensure an Azure Key Vault key URI is returned.

Audit from PowerShell

Run the following command to get Azure Cosmos DB accounts for a given resource group:

```
Get-AzCosmosDBAccount -ResourceGroupName <resource-group>
```

Run the following command to get the account with a given name:

```
$cosmosdb = Get-AzCosmosDBAccount -ResourceGroupName <resource-group> -Name
<cosmos-db>
```

Run the following command to get the Key Vault key URI:

```
$cosmosdb.KeyVaultKeyUri
```

Ensure an Azure Key Vault key URI is returned.

Repeat for each account.

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 1f905d99-2ab7-462c-a6b0-f709acca6c8f **- Name:** 'Azure Cosmos DB accounts should use customer-managed keys to encrypt data at rest'

Remediation:

Remediate from Azure Portal

1. Go to `Azure Cosmos DB`.
2. Select the name of an Azure Cosmos DB account.
3. Under `Settings`, select `Data Encryption`.
4. Set `Encryption Key Type` to `Customer-managed key`.
5. Provide a key URI.
6. Select `Save`.
7. Repeat steps 1-6 for each account requiring remediation.

Default Value:

By default, Azure Cosmos DB accounts are encrypted using service-managed keys.

References:

1. https://learn.microsoft.com/en-gb/azure/cosmos-db/how-to-setup-customer-managed-keys-existing-accounts

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1530	TA0009	M1041

3.6 Ensure the firewall does not allow all network traffic (Automated)

Profile Applicability:

- Level 1

Description:

Do not allow all network traffic. Restrict access to specific IP addresses or ranges.

Rationale:

Allowing all network traffic limits the effectiveness of a firewall.

Impact:

Administrative effort to identify and maintain the list of IP addresses and ranges requiring access to the account.

Audit:

Audit from Azure Portal

1. Go to `Azure Cosmos DB`.
2. Select the name of an Azure Cosmos DB account.
3. Under `Settings`, select `Networking`.
4. Under `Public access`, if `Public network access` is set to `Selected networks`, ensure `0.0.0.0` is not listed under `Firewall` > `IPs`.
5. Repeat steps 1-4 for each account.

Audit from Azure CLI

Run the following command to list Azure Cosmos DB accounts:

```
az cosmosdb list
```

For each account, run the following command to get the list of allowed IP addresses:

```
az cosmosdb show --resource-group <resource-group> --name <cosmos-db> --query
ipRules
```

Ensure that the response does not contain `"0.0.0.0"`.

Audit from PowerShell

Run the following command to get Azure Cosmos DB accounts for a given resource group:

```
Get-AzCosmosDBAccount -ResourceGroupName <resource-group>
```

Run the following command to get the account with a given name:

```
$cosmosdb = Get-AzCosmosDBAccount -ResourceGroupName <resource-group> -Name
<cosmos-db>
```

Run the following command to get the list of allowed IP addresses:

```
$cosmosdb.IpRules
```

Ensure that the response does not contain `0.0.0.0`.

Repeat for each account.

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 12339a85-a25c-4f17-9f82-4766f13f5c4c **- Name:** 'Azure Cosmos DB accounts should not allow traffic from all Azure data centers'

Remediation:

Remediate from Azure Portal

1. Go to `Azure Cosmos DB`.
2. Select the name of an Azure Cosmos DB account.
3. Under `Settings`, select `Networking`.
4. Under `Public access`, `Firewall` > `IPs`, select the `Delete` icon next to `0.0.0.0`.
5. Select `Save`.
6. Repeat steps 1-5 for each account requiring remediation.

Remediate from Azure CLI

For each account requiring remediation, run the following command to update the list of allowed IP addresses, excluding `0.0.0.0`:

```
az cosmosdb update --resource-group <resource-group> --name <cosmos-db-
account> --ip-range-filter <comma-separated-list-of-allowed-ip-addresses>
```

Remediate from PowerShell

For each account requiring remediation, run the following command to update the list of allowed IP addresses, excluding `0.0.0.0`:

```
Update-AzCosmosDBAccount -ResourceGroupName <resource-group> -Name <cosmos-
db-account> -IpRule <comma-separated-list-of-allowed-ip-addresses>
```

Default Value:

By default, the firewall does not allow all network traffic.

References:

1. https://learn.microsoft.com/en-gb/azure/cosmos-db/how-to-configure-firewall#allow-requests-from-global-azure-datacenters-or-other-sources-within-azure

Additional Information:

Setting `publicNetworkAccess` to `Disabled` takes precedence over `Accept connections from within public Azure datacenters`.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1530	TA0009	M1037

3.7 Ensure that Cosmos DB Logging is Enabled (Manual)

Profile Applicability:

- Level 1

Description:

Cosmos DB logs should be captured to track events relevant to auditing and diagnostics.

Rationale:

Logging of changes, events, and information related to Cosmos DB provides a diagnostic tool and a forensic record of activity. An effective set of logs help provide integrity and availability to the service and contribute to the effectiveness of detective systems such as a SIEM.

Impact:

There may be additional storage costs for logging a large amount of events. Potentially only keep logs for a certain timeframe before they are deleted.

Audit:

NOTE: This procedure assumes a Log Analytics Workspace or other logging destination already exists. Please see attached resources on this setup.

Audit from Azure Portal

1. From `Azure CosmosDB`, select the database you wish to audit.
2. Scroll down in the left column and select `> Monitoring`.
3. Select `Diagnostic Settings`.
4. Determine if there are any diagnostic settings that are being sent to a logging location. You will need to open each listed and determine if `allLogs` under `Category groups` is checked.

Audit from PowerShell

1. Get the CosmosDB accounts for a specific resource group. Repeat for each resource group as necessary.

```
Get-AzCosmosDBAccount -ResourceGroupName <resource group name>
```

2. For each CosmosDB, determine which log categories are enabled for each account using the *Id* of each CosmosDB Account.

```
Get-AzDiagnosticSetting -ResourceId <CosmosDB Account Id>
```

3. Within the output of the above command, ensure the log categories have *Enabled* set to *true*

Remediation:

NOTE: This procedure assumes a Log Analytics Workspace or other logging destination already exists. Please see attached resources on this setup.

Remediate from Azure Portal

1. From `Azure CosmosDB`, select the database you wish to audit.
2. Scroll down in the left column and select `> Monitoring`.
3. Select `Diagnostic Settings`.
4. Select `+ Add Diagnostic Setting`
5. Enter your name for this setting in `Diagnostic Setting Name`.
6. Select `allLogs` under `Category groups`
7. Select `Send to Log Analytics workspace` or other logging solution under `Destination details`.
8. Select your Azure subscription, and your log analytics workspace, or other connection details depending on your logging solution.
9. Select `Save` in the top left corner.

Remediate from PowerShell For each CosmosDB account out of compliance, enable the logging by running the following command:

```
$categories = @(
    @{
        Category="ControlPlaneRequests";
        Enabled=$true;
        RetentionPolicy=@{ Enabled=$false; Days=0 }
    },
    @{
        Category="DataPlaneRequests";
        Enabled=$true;
        RetentionPolicy=@{ Enabled=$false; Days=0 }
    },
    @{
        Category="MongoRequests";
        Enabled=$true;
        RetentionPolicy=@{ Enabled=$false; Days=0 }
    },
    @{
        Category="SqlRequests";
        Enabled=$true;
        RetentionPolicy=@{ Enabled=$false; Days=0 }
    },
    @{
        Category="GremlinQueries";
        Enabled=$true;
        RetentionPolicy=@{ Enabled=$false; Days=0 }
    },
    @{
        Category="TableRequests";
        Enabled=$true;
        RetentionPolicy=@{ Enabled=$false; Days=0 }
    }
)

Set-AzDiagnosticSetting -Name <name of new CosmosDB diagnostic setting> -
ResourceId <CosmosDB Account Id> -WorkspaceId <log analytics workspace id> -
Categories $categories -Enabled $true
```

Default Value:

By default, event logging for Azure Cosmos DB is not enabled.

References:

1. https://learn.microsoft.com/en-us/azure/azure-monitor/logs/quick-create-workspace
2. https://learn.microsoft.com/en-us/azure/cosmos-db/monitor
3. https://www.azadvertizer.net/azpolicyadvertizer/45c6bfc7-4520-4d64-a158-730cd92eedbc.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

4 Azure Data Factory

This section covers security best practice recommendations for Azure Data Factory.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Data Factory

Azure Product Page:

- https://azure.microsoft.com/en-us/products/data-factory/

Azure Data Factory service overview:

- https://learn.microsoft.com/en-us/azure/data-factory/

Microsoft Cloud Security Baseline for Azure Data Factory:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/data-factory-security-baseline

4.1 Ensure Data Factory is encrypted using Customer Managed Keys (Manual)

Profile Applicability:

- Level 2

Description:

Customer-managed keys introduce additional depth to security by providing a means to manage access control for encryption keys. Where compliance and security frameworks indicate the need, and organizational capacity allows, sensitive data at rest can be encrypted using customer-managed keys (CMK) rather than Microsoft-managed keys.

Rationale:

By default in Azure, data at rest tends to be encrypted using Microsoft-managed keys. If your organization wants to control and manage encryption keys for compliance and defense-in-depth, customer-managed keys can be established.

Configuring the storage account with the activity log export container to use CMKs provides additional confidentiality controls on log data, as a given user must have read permission on the corresponding storage account and must be granted decrypt permission by the CMK.

While it is possible to automate the assessment of this recommendation, the assessment status for this recommendation remains 'Manual' due to ideally limited scope. The scope of application—which workloads CMK is applied to—should be carefully considered to account for organizational capacity and targeted to workloads with specific need for CMK.

Impact:

If the key expires due to setting the 'activation date' and 'expiration date', the key must be rotated manually.

Using customer-managed keys may also incur additional man-hour requirements to create, store, manage, and protect the keys as needed.

Audit:

Audit from Azure Portal

1. From `Azure Data Factory` select the Data Factory to audit.
2. From the `Overview` selection scroll down and select `Launch Studio`.
3. Select the `wrench and briefcase` icon named `Manage`.
4. In the left column scroll down to under `Security` and select `Customer managed key`.
5. Audit the keys listed here.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 4ec52d6d-beb7-40c4-9a9e-fe753254690e **- Name:** 'Azure data factories should be encrypted with a customer-managed key'

Remediation:

Remediate from Azure Portal

1. Retrieve the key identifier for a key in a Key Vault located in the same subscription and region as your Azure Data Factory.
2. From the `Azure Data Factory` service, select the Data Factory to audit.
3. From the `Overview` selection scroll down and select `Launch Studio`.
4. Select the `wrench and briefcase` icon named `Manage`.
5. In the left column scroll down to under `Security` and select `Customer managed key`.
6. Select `Add key`.
7. Under `Azure Key Vault key URL` enter in the key identifier of the key to be used.
8. Select `Save`.

Default Value:

By default in Azure, data at rest tends to be encrypted using Microsoft-managed keys.

References:

1. https://learn.microsoft.com/en-us/azure/data-factory/enable-customer-managed-key

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1530	TA0009	M1041

4.2 Ensure Data Factory is using Managed Identities (Automated)

Profile Applicability:

- Level 1

Description:

Managed identities are the roles that Azure services assume to access other services or resources. Access and permissions may be set on these roles to set the scope and reach of what a service can access. Setting a service to use a managed identity also prevents the need to store credentials in code or other less secure options.

Rationale:

Managed identities eliminate the need to store and manage credentials to access Azure resources. Scoping permissions of a managed identity to a specific set of resources also prevents unwanted access elsewhere.

Impact:

Initial administrative overhead to configure and manage role assignments for managed identities.

Audit:

Audit from Azure Portal

1. From `Data Factories` select a factory to audit.
2. In the left column expand `> Settings`.
3. Select `Managed identities`.
4. In the top `System assigned` menu, determine if the default identity is in use under `Status`, by whether this is set to `On`.
5. Determine if there are any custom identities assigned to this resource by selecting in the top menu `User Assigned`.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** f78ccdb4-7bf4-4106-8647-270491d2978a **- Name:** 'Azure Data Factory linked services should use system-assigned managed identity authentication when it is supported'

Remediation:

Remediate from Azure Portal

1. From `Data Factories` select a factory to remediate.
2. In the left column expand `> Settings`.
3. Select `Managed identities`.
4. From the `System Assigned` tab, under `Permissions` select `Azure role assignments`.
5. `Select + Add role assignments (Preview)`.
6. Select a `Scope`, `Subscription` and `Role` to be added.
7. Select `Save`

Default Value:

By default, Data Factories use a system assigned managed identity, with no permissions to resources set.

References:

1. https://learn.microsoft.com/en-us/entra/identity/managed-identities-azure-resources/overview
2. https://learn.microsoft.com/en-us/azure/data-factory/data-factory-service-identity

4.3 Ensure that Data Factory is using Azure Key Vault to store Credentials and Secrets (Manual)

Profile Applicability:

- Level 2

Description:

Azure Key Vault is a way to securely store secrets and keys, and create role based access control permissions to services and users to access them.

Rationale:

Use of Azure Key Vault is greatly recommended over less secure options like hard coding credentials into code.

Impact:

This will create technical overhead as your organization will need to manage the lifecycle, expiration, and rotation of secrets and keys to fit your security baseline.

Audit:

Audit from Azure Portal

1. From `Data Factories` select a factory to audit.
2. Under the `Overview` selection scroll down in the right pane and select `Launch studio` under `Azure Data Factory Studio`.
3. In the left column select the briefcase and wrench for `Manage`.
4. In the left column select `Linked Services` under `Connections`.
5. Browse the linked services to determine if there is a connection to an Azure key vault. It has a circle icon with a key in it.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 127ef6d7-242f-43b3-9eef-947faf1725d0 **- Name:** 'Azure Data Factory linked services should use Key Vault for storing secrets'

Remediation:

Remediate from Azure Portal

Retrieve Managed Identity Object ID

1. From `Azure Data Factories` select a factory to link to an Azure Key Vault.
2. In the left column, expand `> Settings` and select `Properties`.
3. Select `Managed Identity Object ID` and save this code for later.

Set Permissions for Key Vault

Note this presumes the use of RBAC Access control, not Access policies.

1. From `Key vaults` select a key vault to grant access to.
2. Select `+ Add`, and select `Add role assignment` from the dropdown.
3. For the `Role`, search for `key vault`. Listed are various permissions to be assigned. Determine your organization's permission need, but `Key Vault Reader` is satisfactory for basic key and secrets access.
4. Select `Next`
5. In the new screen, next to `Assign access to`, select Managed identity.
6. Next to Members select `+ Select members`.
7. Choose your subscription, and either under `Managed identity` scroll to `Data Factory` and select it, or search by your Data Factory's name.
8. Select your Data Factory.
9. Choose `Select`.
10. Select `Review + assign`.

Create Connection Between Key Vault and Data Factory

1. From `Data Factories` select your data factory.
2. Under the `Overview` selection scroll down in the right pane and select `Launch studio` under `Azure Data Factory Studio`.
3. In the left column select the briefcase and wrench for `Manage`.
4. In the left column select `Linked Services` under `Connections`.
5. Select `+ New`.
6. Search for `Azure Key Vault` and select it.
7. In the new window, name your connection and enter a desired description.
8. Under `Azure key vault selection method`, choose `From Azure Subscription`.
9. Select your Azure Subscription.
10. Select your key vault by name.
11. Under `Authentication Method` select `System-assigned managed identity` or `User-assigned managed identity` depending on what managed identity is in use on your data factory.
12. Select `Create`.

Default Value:

By default Azure Data Factories do not use Azure Key Vault to store credentials or secrets.

References:

1. https://learn.microsoft.com/en-us/azure/data-factory/store-credentials-in-key-vault
2. https://learn.microsoft.com/en-us/azure/data-factory/data-factory-service-identity#retrieve-managed-identity

4.4 Ensure that Data Factory is using RBAC to manage privilege assignment (Manual)

Profile Applicability:

- Level 2

Description:

Role Based Access Control (RBAC) is setting permissions to the role that a user occupies. Often the user is added to a group which the account inherits permissions from. This is different than Access Policies which are used on an individual case by case basis for each user.

Rationale:

RBAC enhances security by limiting user privilege to only what is necessary for a job role, reducing the risk of unauthorized access. Additionally, RBAC aids compliance with regulations and provides clear accountability by tracking access activities linked to specific roles.

Impact:

There will be a slight increase in technical overhead in that user permissions will need to be manually assigned. However once added to a group, permissions may be edited for every account in the group at one time.

Audit:

Audit from Azure Portal

1. From `Data Factories` select a data factory to audit.
2. In the left column select `Access control (IAM)`.
3. To check an individual account or group, in the horizontal row, select `Check access`, then search for a user, group, or managed identity.
4. To check all roles, in the horizontal row select `Role assignments`, and scroll through all the roles that have permission to this data factory.

Remediation:

Remediate from Azure Portal

1. From `Data Factories` select a data factory to audit.
2. In the left column select `Access control (IAM)`.
3. Select `+ Add \/` and then `Add role assignment`.
4. Select the builtin or custom role to be added. Then select `Next`.
5. Next to `Assign access to` select either `User, group, or service principal` or `Managed identity` to be added to this role.

6. Choose `Select members`, then search for the resource that is to be added to this role.
7. Enter a description if desired.
8. Select `Next`, review your choices, then `Review + assign`.

Default Value:

By default, Data factories use RBAC but only with permissions for owners to make changes.

References:

1. https://learn.microsoft.com/en-us/azure/data-factory/concepts-roles-permissions

5 Azure Database for MySQL

This section covers security best practice recommendations for Azure Database for MySQL.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Database for MySQL

Azure Product Page:

- https://azure.microsoft.com/en-us/products/mysql/

Azure Database for MySQL service overview:

- https://learn.microsoft.com/en-us/azure/mysql/

Microsoft Cloud Security Baseline for Azure Database for MySQL:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-database-for-mysql-flexible-server-security-baseline

5.1 Ensure Azure Database for MySQL uses Customer Managed Keys for Encryption at Rest (Manual)

Profile Applicability:

- Level 2

Description:

Enable sensitive data encryption at rest using Customer Managed Keys (CMK) rather than Microsoft Managed keys (MMK).

Rationale:

By default, data in Azure Database for MySQL is encrypted using Microsoft Service-Managed Keys (MMK) which constitutes an implied trust. If an organization wishes to control and manage encryption keys, however, customer-managed keys (CMK) can be supplied. The provided key is used to protect and control access to the key that encrypts the data. You can also choose to automatically update the key version used for Azure Database for MySQL encryption whenever a new version is available in the associated Key Vault.

NOTE: This is primarily recommended where control of encryption keys is specified by compliance or security framework requirements. In many circumstances, Microsoft Managed Key encryption is an acceptable method of accomplishing encryption at rest.

Impact:

If the key expires by setting the 'activation date' and 'expiration date', the user must rotate the key manually.

Using Customer Managed Keys may also incur additional man-hour requirements to create, store, manage, and protect the keys as needed.

Audit:

Audit from Azure Portal

1. From `Azure Database for MySQL` select the server you wish to audit.
2. In the left column expand `> Security`.
3. Select `Data Encryption`.
4. Determine if `Customer-managed key` is selected.

Remediation:

Remediate from Azure Portal

1. From `Azure Database for MySQL` select the server you wish to audit.
2. In the left column expand `> Security`.
3. Select `Data Encryption`.
4. Select `Customer-managed key`.
5. In the window that opens, use a `User assigned managed identity` by either creating or selecting one.
6. Choose a key selection method. For `Enter a key identifier`, enter the for URL for the key in Azure Key vault. For `Select a key`, navigate through the menu and choose the location of your key store by subscription, and whether it is a key vault or managed HSM.
7. Once a key is chosen, select `Save`. Verify on the next window that your changes have taken effect.

Default Value:

Unless selected at resource creation, by default Azure Database for MySQL uses Microsoft Managed Keys.

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/concepts-customer-managed-key

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

5.2 Ensure Azure Database for MySQL uses only Microsoft Entra Authentication (Automated)

Profile Applicability:

- Level 1

Description:

Ensuring that Microsoft Entra Authentication is the only authentication method prevents the local MySQL authentication from being used.

Rationale:

The use of a centralized Identity and Access Management (IAM) solution such as Microsoft Entra ID is highly recommended for all activity related to Identity, Authentication, Authorization, and Accountability.

Decentralized IAM – such as local authentication methods – may present additional vulnerability and introduce avoidable administrative complexity.

Audit:

Audit from Azure Portal

1. From `Azure Database for MySQL` select a server to audit.
2. Under the Security section, click `Authentication`
3. In the main window, under the Authentication header, ensure that "Assign Access to:" reflects the selection of `Microsoft Entra authentication only`.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 40e85574-ef33-47e8-a854-7a65c7500560 **- Name:** 'Azure MySQL flexible server should have Microsoft Entra Only Authentication enabled'

Remediation:

Audit from Azure Portal

1. From `Azure Database for MySQL` select a server to remediate.
2. Under the Security section, click `Authentication`
3. In the main window, under the Authentication header where "Assign Access to:" provides three options, select `Microsoft Entra authentication only`.

Default Value:

By default, Azure Database for MySQL uses `MySQL authentication only`.

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/how-to-azure-ad
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-identity-management

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 Centralize Account Management Centralize account management through a directory or identity service.		●	●
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

5.3 Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL (Automated)

Profile Applicability:

- Level 2

Description:

Setting public networks to disabled prevents requests from the public internet.

Rationale:

Disabling public network access prevents Azure Database for MySQL servers from communicating with the public internet and requires the use of Private endpoints for granular network control and segmentation.

Impact:

Disabling 'Public Network Access' forces the requirement of the use of Private Endpoints for network connectivity which will require some additional consideration from a network architecture perspective and will introduce cost based on the inbound/outbound data being processed by the Private Endpoint.

Audit:

Audit from Azure Portal

1. From `Azure Database for MySQL` select the database you wish to audit.
2. In the left column expand `> Settings`.
3. Select `Networking`.
4. Ensure that Public network access is `not selected`

Audit from Powershell

1. Run the following command with the identifying details for your subscription.

```
Get-AzMySqlFlexibleServer -name <servername> -ResourceGroupName
<resourcegroupname> | Select-Object -property NetworkPublicNetworkAccess
```

2. Ensure that Public network access is `Disabled`.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** c9299215-ae47-4f50-9c54-8a392f68a052 **- Name:** 'Public network access should be disabled for MySQL flexible servers'

Remediation:

Remediate from Azure Portal

1. From `Azure Database for MySQL` select the database you wish to audit.
2. In the left column expand `> Settings`.
3. Select `Networking`.
4. Uncheck the checkbox under `Public Access`

Default Value:

Unless specified at resource creation, Azure Database for MySQL by default allows public network access, but authenticates requests.

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/how-to-networking-private-link-deny-public-access

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

5.4 Ensure Private Endpoints Are Used for Azure MySQL Databases (Automated)

Profile Applicability:

- Level 2

Description:

Private links make resources available via a private endpoint to a network you select. Tunneling between subscriptions, resource groups, without the need for traditional network routing.

Rationale:

For sensitive data, private endpoints allow granular control of which services can communicate with Azure MySQL and ensure that this network traffic is private. This can be set this up on a case by case basis for each service to be connected.

Impact:

A private endpoint will expose your MySQL database to the network selected, where it can be accessed by either IP or FQDN.

Audit:

Audit from Azure Portal

1. From `Azure Database for MySQL flexible servers` select a server to audit.
2. In the column expand `> Settings`.
3. Select `Networking`.
4. Scroll down to the bottom to determine if there are any private endpoints attached to the server.

Remediation:

Audit from Azure Portal

1. From `Azure Database for MySQL flexible servers` select a server to audit.
2. In the column expand `> Settings`.
3. Select `Networking`.
4. Scroll down to the bottom, and select `+ Create private endpoint`.
5. Select a subscription and resource group.
6. Enter an instance name, network interface name, and select the same region that your MySQL server is in.
7. Verify that the information on `Resource` is correct. Then select `Next`
8. Select the virtual network, and subnet and select `Next`.
9. Choose whether to use a dynamic or static IP address and select `Next`.

10. Choose `Yes` or `No` on `Integreate with private DNS zone`.
11. If `Yes` then select the subscription and resource group, then select `Next`.
12. Enter any desired tags, then select `Next`.
13. Verify the information, then select `Create`.

Default Value:

Unless specified at resource creation, by default Azure MySQL does not have a private endpoint attached.

References:

1. https://learn.microsoft.com/en-us/azure/azure-sql/database/private-endpoint-overview?view=azuresql
2. https://learn.microsoft.com/en-us/azure/private-link/create-private-endpoint-powershell?tabs=dynamic-ip

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	12.2 Establish and Maintain a Secure Network Architecture Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

5.5 Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server (Automated)

Profile Applicability:

- Level 2

Description:

Enable `audit_log_enabled` on `MySQL flexible servers`.

Rationale:

Enabling `audit_log_enabled` helps MySQL Database to log items such as connection attempts to the server, DDL/DML access, and more. Log data can be used to identify, troubleshoot, and repair configuration errors and suboptimal performance.

Impact:

There are further costs incurred for storage of logs. For high traffic databases these logs will be significant. Determine your organization's needs before enabling.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL Servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `audit_log_enabled`.
5. Ensure that the `VALUE` for `audit_log_enabled` is `ON`.

Audit from Azure CLI

Ensure the below command returns a `value` of `on`:

```
az mysql flexible-server parameter show --resource-group <resourceGroup> --
server-name <serverName> --name audit_log_enabled
```

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup> -
ServerName <serverName> -Name audit_log_enabled
```

Remediation:

Remediate from Azure Portal

Part 1 - Turn on audit logs

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. Set `audit_log_enabled` to `ON`.
5. Click `Save`.

Part 2 - Capture audit logs (diagnostic settings is for example only, send these logs to the appropriate data sink for your logging needs)

1. Under Monitoring, select `Diagnostic settings`.
2. Select `+ Add diagnostic setting`.
3. Provide a diagnostic setting name.
4. Under Categories, select `MySQL Audit Logs`.
5. Specify destination details.
6. Click `Save`.

It may take up to 10 minutes for the logs to appear in the configured destination.

Remediate from Azure CLI

Use the below command to enable `audit_log_enabled` :

```
az mysql flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name audit_log_enabled --value on
```

Remediate from PowerShell

Use the below command to enable `audit_log_enabled` :

```
Update-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup>
-ServerName <serverName> -Name audit_log_enabled -Value on
```

Default Value:

`audit_log_enabled` is set to `OFF` by default

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/tutorial-configure-audit
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation
3. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/tutorial-configure-audit#configure-auditing-by-using-the-azure-cli
4. https://www.azadvertizer.net/azpolicyadvertizer/4dc90661-5d91-41f1-be00-d243f6f3fe9c.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

5.6 Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server (Automated)

Profile Applicability:

- Level 2

Description:

Set `audit_log_events` to include `CONNECTION` on `MySQL flexible servers`.

Rationale:

Enabling `CONNECTION` helps MySQL Database to log items such as successful and failed connection attempts to the server. Log data can be used to identify, troubleshoot, and repair configuration errors and suboptimal performance.

Impact:

There are further costs incurred for storage of logs. For high traffic databases these logs will be significant. Determine your organization's needs before enabling.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `audit_log`.
5. Ensure that the `VALUE` for `audit_log_enabled` is `ON`.
6. Ensure that the `VALUE` for `audit_log_events` includes `CONNECTION`.

Audit from Azure CLI

Ensure the below command returns a `value` that includes `CONNECTION`:

```
az mysql flexible-server parameter show --resource-group <resourceGroup> --
server-name <serverName> --name audit_log_events
```

Audit from PowerShell

Ensure the below command returns a `Value` that includes `CONNECTION`:

```
Get-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup> -
ServerName <serverName> -Name audit_log_events
```

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `audit_log`.
5. Set `audit_log_enabled` to `ON`.
6. In the drop-down next to `audit_log_events`, check `CONNECTION`.
7. Click `Save`.
8. Under `Monitoring`, select `Diagnostic settings`.
9. Select `+ Add diagnostic setting`.
10. Provide a diagnostic setting name.
11. Under `Categories`, select `MySQL Audit Logs`.
12. Specify destination details.
13. Click `Save`.

It may take up to 10 minutes for the logs to appear in the configured destination.

Remediate from Azure CLI

Use the below command to set `audit_log_events` to `CONNECTION`:

```
az mysql flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name audit_log_events --value CONNECTION
```

Remediate from PowerShell

Use the below command to set `audit_log_events` to `CONNECTION`:

```
Update-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup>
-ServerName <serverName> -Name audit_log_events -Value CONNECTION
```

Default Value:

By default `audit_log_events` is set to `CONNECTION`.

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/concepts-audit-logs
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation
3. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/tutorial-configure-audit
4. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/tutorial-configure-audit#configure-auditing-by-using-the-azure-cli

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

5.7 Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server (Manual)

Profile Applicability:

- Level 2

Description:

Enable error logs on MySQL flexible servers.

Rationale:

With `error_server_log_file` enabled, MySQL Database will log database errors to a logging solution. These logs assist in producing a forensic trail that can be used for investigation or for detection when paired with a SIEM.

Impact:

There are further costs incurred for storage of logs. For high traffic databases these logs will be significant. Determine your organization's needs before enabling.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL Servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the row under `Save`, select `All`.
5. In the filter bar, type `error_server_log_file`.
6. Ensure that the `VALUE` for `error_server_log_file` is `ON`.

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup> -
ServerName <serverName> -Name error_server_log_file
```

Remediation:

Remediate from Azure Portal

Part 1 - Turn on audit logs

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. Set `error_server_log_file` to `ON`.
5. Click `Save`.

Part 2 - Capture audit logs (diagnostic settings is for example only, send these logs to the appropriate data sink for your logging needs)

1. Under Monitoring, select `Diagnostic settings`.
2. Select `+ Add diagnostic setting`.
3. Provide a diagnostic setting name.
4. Under Categories, select `MySQL Audit Logs`.
5. Specify destination details.
6. Click `Save`.

It may take up to 10 minutes for the logs to appear in the configured destination.

Remediate from PowerShell

Use the below command to enable `error_server_log_file`:

```
Update-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup>
-ServerName <serverName> -Name error_server_log_file -Value on
```

Default Value:

`error_server_log_file` is set to `OFF` by default

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/tutorial-configure-audit
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation
3. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/concepts-error-logs

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

5.8 Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server (Automated)

Profile Applicability:

- Level 1

Description:

Enable `require_secure_transport` on `MySQL flexible servers`.

Rationale:

The Secure Sockets Layer (SSL) protocol encrypts network traffic transiting between server and client. Enforcing SSL connections between database server and client applications helps protect against "man in the middle" attacks by encrypting the data stream between the server and application.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `require_secure_transport`.
5. Ensure that the value for require_secure_transport is `ON`.

Audit from Azure CLI

Ensure the below command returns a `value` of `on`:

```
az mysql flexible-server parameter show --resource-group <resourceGroup> --
server-name <serverName> --name require_secure_transport
```

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup> -
ServerName <serverName> -Name require_secure_transport
```

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `require_secure_transport`.
5. Set the `VALUE` for `require_secure_transport` to `ON`.
6. Click `Save`.

Remediate from Azure CLI

Use the below command to enable `require_secure_transport`:

```
az mysql flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name require_secure_transport --value on
```

Remediate from PowerShell

Use the below command to enable `require_secure_transport`:

```
Update-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup>
-ServerName <serverName> -Name require_secure_transport -Value on
```

Default Value:

Azure Database for MySQL when provisioned through the Azure portal or CLI will require SSL connections by default.

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/concepts-networking#tls-and-ssl
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-data-protection#dp-3-encrypt-sensitive-data-in-transit

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1040	TA0006, TA0007	M1041

5.9 Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server (Automated)

Profile Applicability:

- Level 1

Description:

Ensure `tls_version` on `MySQL flexible servers` is set to use TLS version 1.2 or higher.

Rationale:

The Secure Sockets Layer (SSL) protocol encrypts network traffic transiting between server and client.

Using only the most recent versions of SSL protocols (TLS version 1.2 and higher) eliminates susceptibility to known exploited vulnerabilities of outdated versions of TLS. If TLS 1.2 does not provide additional granular configuration options for supported cipher suites, there's a chance that default ciphers which employ Cipher Block Chaining (CBC) mode may be enabled which would introduce Padding Oracle types of vulnerabilities. TLS 1.3 does not support CBC mode ciphers by default and by default supports GCM ciphers which include an extra authentication step during the clear text to cipher text encryption process.

TLS version 1.3 is preferable where it is possible to implement.

Versions 1.0 and 1.1 of TLS are no longer considered secure. These versions should not be used or permitted where data integrity and confidentiality are required.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `tls_version`.
5. Ensure `tls_version` is set to `TLSv1.2` (or higher).

Audit from Azure CLI

Ensure the `value` of the below command contains `TLSv1.2` or higher, and does not contain anything lower than `TLSv1.2`:

```
az mysql flexible-server parameter show --resource-group <resourceGroup> --
server-name <serverName> --name tls_version
```

Example output:

```
{
  "allowedValues": "TLSv1,TLSv1.1,TLSv1.2",
  "dataType": "Set",
  "defaultValue": "TLSv1.2",
  "description": "Which protocols the server permits for encrypted
connections. By default, TLS 1.2 is enforced",
  "id":
"/subscriptions/<subscriptionId>/resourceGroups/<resourceGroupName>/providers
/Microsoft.DBforMySQL/flexibleServers/<serverName>/configurations/tls_version
",
  "isConfigPendingRestart": "False",
  "isDynamicConfig": "False",
  "isReadOnly": "False",
  "name": "tls_version",
  "resourceGroup": "<resourceGroupName>",
  "source": "system-default",
  "systemData": null,
  "type": "Microsoft.DBforMySQL/flexibleServers/configurations",
  "value": "TLSv1.2"
}
```

Audit from PowerShell

Ensure the `Value` of the below command contains `TLSv1.2` or higher, and does not contain anything lower than `TLSv1.2`:

```
Get-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup> -
ServerName <ServerName> -Name tls_version
```

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for MySQL flexible servers`.
3. For each database, under `Settings`, click `Server parameters`.
4. In the filter bar, type `tls_version`.
5. Click on the VALUE dropdown next to `tls_version`, and check `TLSv1.2` (or higher).
6. Uncheck anything lower than `TLSv1.2`.
7. Click `Save`.

Remediate from Azure CLI

Use the below command to update MySQL flexible servers to use TLS version 1.2:

```
az mysql flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name tls_version --value TLSv1.2
```

Remediate from PowerShell

Use the below command to update MySQL flexible servers to use TLS version 1.2:

```
Update-AzMySqlFlexibleServerConfiguration -ResourceGroupName <resourceGroup>
-ServerName <serverName> -Name tls_version -Value TLSv1.2
```

Default Value:

By default, TLS is set to v1.2 for MySQL Flexible servers.

References:

1. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/concepts-networking#tls-and-ssl
2. https://learn.microsoft.com/en-us/azure/mysql/flexible-server/how-to-connect-tls-ssl
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-data-protection#dp-3-encrypt-sensitive-data-in-transit

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1040	TA0006, TA0007	M1041

6 Azure Database for PostgreSQL

This section covers security best practice recommendations for Azure Database for PostgreSQL.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Database for PostgreSQL

Azure Product Page:

- https://azure.microsoft.com/en-us/products/postgresql/

Azure Database for PostgreSQL service overview:

- https://learn.microsoft.com/en-us/azure/postgresql/

Microsoft Cloud Security Baseline for Azure Database for PostgreSQL:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-database-for-postgresql-flexible-server-security-baseline

6.1 Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest (Manual)

Profile Applicability:

- Level 2

Description:

Enable sensitive data encryption at rest using Customer Managed Keys (CMK) rather than Microsoft Managed keys (MMK).

Rationale:

By default, data in Azure Database for PostgreSQL is encrypted using Microsoft Service Managed Keys ('SMK' or 'MMK') which constitutes an implied trust. If an organization wishes to control and manage encryption keys, however, customer-managed keys (CMK) can be supplied. The provided key is used to protect and control access to the key that encrypts the data. You can also choose to automatically update the key version used for Azure Database for MySQL encryption whenever a new version is available in the associated Key Vault.

NOTE: This is primarily recommended where control of encryption keys is specified by compliance or security framework requirements. In many circumstances, Microsoft Managed Key encryption is an acceptable method of accomplishing encryption at rest.

Impact:

If the key expires by setting the 'activation date' and 'expiration date', the user must rotate the key manually.

Using Customer Managed Keys may also incur additional man-hour requirements to create, store, manage, and protect the keys as needed.

Audit:

Audit from Azure Portal

1. From `Azure Database for PostgreSQL` select the server you wish to audit.
2. In the left column expand `> Security`.
3. Select `Data Encryption`.
4. Determine if `Customer-managed key` is selected.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 12c74c95-0efd-48da-b8d9-2a7d68470c92 **- Name:** 'PostgreSQL flexible servers should use customer-managed keys to encrypt data at rest'

Remediation:

Remediate from Azure Portal

1. From `Azure Database for PostgreSQL` select the server you wish to audit.
2. In the left column expand `> Security`.
3. Select `Data Encryption`.
4. Select `Customer-managed key`.
5. In the window that opens, use a `User assigned managed identity` by either creating or selecting one.
6. Choose a key selection method. For `Enter a key identifier`, enter the for URL for the key in Azure Key vault. For `Select a key`, navigate through the menu and choose the location of your key store by subscription, and whether it is a key vault or managed HSM.
7. Once a key is chosen, select `Save`. Verify on the next window that your changes have taken effect.

Default Value:

Unless selected at resource creation, by default Azure Database for PostgreSQL uses Microsoft Managed Keys.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/security/security-data-encryption

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

6.2 Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication (Manual)

Profile Applicability:

- Level 1

Description:

Ensuring that Microsoft Entra Authentication is the only authentication method prevents the local PostgreSQL authentication from being used.

Rationale:

The use of a centralized Identity and Access Management (IAM) solution such as Microsoft Entra ID is highly recommended for all activity related to Identity, Authentication, Authorization, and Accountability.

Decentralized IAM – such as local authentication methods – may present additional vulnerability and introduce avoidable administrative complexity.

Audit:

Audit from Azure Portal

1. From `Azure Database for PostgreSQL` select a server to audit.
2. Under the Security section, click `Authentication`
3. In the main window, under the Authentication header, ensure that "Authentication method:" reflects the selection of `Microsoft Entra authentication only`.

Remediation:

Audit from Azure Portal

1. From `Azure Database for PostgreSQL` select a server to remediate.
2. Under the Security section, click `Authentication`
3. In the main window, under the Authentication header where "Authentication method:" provides three options, select `Microsoft Entra authentication only`.

Default Value:

By default, Azure Database for PostgreSQL uses `PostgreSQL authentication only`.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/security/security-entra-concepts
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-identity-management

Additional Information:

A preview policy currently exists which will be added to the Audit Procedure when it is no longer in preview: https://www.azadvertizer.net/azpolicyadvertizer/fa498b91-8a7e-4710-9578-da944c68d1fe.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 Centralize Account Management Centralize account management through a directory or identity service.		●	●
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

6.3 Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL (Automated)

Profile Applicability:

- Level 2

Description:

Setting public networks to disabled prevents requests from the public internet.

Rationale:

Disabling public network access prevents Azure Database for PostgreSQL servers from communicating with the public internet and requires the use of Private endpoints for granular network control and segmentation.

Impact:

Disabling 'Public Network Access' forces the requirement of the use of Private Endpoints for network connectivity which will require some additional consideration from a network architecture perspective and will introduce cost based on the inbound/outbound data being processed by the Private Endpoint.

Audit:

Audit from Azure Portal

1. From `Azure Database for PostgreSQL` select the database you wish to audit.
2. In the left column expand `> Settings`.
3. Select `Networking`.
4. Ensure that Public network access is `not selected`

Audit from Powershell

1. Run the following command with the identifying details for your subscription.

```
Get-AzPostgreSqlFlexibleServer -name <servername> -ResourceGroupName
<resourcegroupname> | Select-Object -property NetworkPublicNetworkAccess
```

1. Ensure that Public network access is `Disabled`.

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 5e1de0e3-42cb-4ebc-a86d-61d0c619ca48 **- Name:** 'Public network access should be disabled for PostgreSQL flexible servers'

Remediation:

Remediate from Azure Portal

1. From `Azure Database for PostgreSQL` select the database you wish to remediate.
2. In the left column expand `> Settings`.
3. Select `Networking`.
4. Uncheck the checkbox under `Public Access`

Default Value:

Unless specified at resource creation, Azure Database for PostgreSQL by default allows public network access, but authenticates requests.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/concepts-firewall-rules
2. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/how-to-manage-firewall-cli
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-network-security#ns-1-establish-network-segmentation-boundaries
4. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-network-security#ns-6-deploy-web-application-firewall
5. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/how-to-networking-servers-deployed-public-access-disable-public-access?tabs=portal-disable-public-access

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1580	TA0007	M1018

6.4 Ensure Private Endpoints Are Used for Azure Database for PostgreSQL (Automated)

Profile Applicability:

- Level 2

Description:

Private links make resources available via a private endpoint to a network you select. Tunneling between subscriptions, resource groups, without the need for traditional network routing.

Rationale:

For sensitive data, private endpoints allow granular control of which services can communicate with PostgreSQL Servers and ensure that this network traffic is private. This can be set this up on a case by case basis for each service to be connected.

Impact:

A private endpoint will expose your PostgreSQL database to the network selected, where it can be accessed by either IP or FQDN.

Audit:

Audit from Azure Portal

1. From `Azure Database for PostgreSQL servers` select a server to audit.
2. In the column expand `> Settings`.
3. Select `Networking`.
4. Scroll down to the bottom to determine if there are any private endpoints attached to the server.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 5375a5bb-22c6-46d7-8a43-83417cfb4460 **- Name:** 'Private endpoint should be enabled for PostgreSQL flexible servers'

Remediation:

Audit from Azure Portal

1. From `Azure Database for PostgreSQL flexible servers` select a server to audit.
2. In the column expand `> Settings`.
3. Select `Networking`.
4. Scroll down to the bottom, and select `+ Create private endpoint`.
5. Select a subscription and resource group.
6. Enter an instance name, network interface name, and select the same region that your PostgreSQL server is in.
7. Verify that the information on `Resource` is correct. Then select `Next`
8. Select the virtual network, and subnet and select `Next`.
9. Choose whether to use a dynamic or static IP address and select `Next`.
10. Choose `Yes` or `No` on `Integreate with private DNS zone`.
11. If `Yes` then select the subscription and resource group, then select `Next`.
12. Enter any desired tags, then select `Next`.
13. Verify the information, then select `Create`.

Default Value:

Unless specified at resource creation, by default Azure Database for PostgreSQL does not have a private endpoint attached.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/network/concepts-networking-private-link

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	12.2 Establish and Maintain a Secure Network Architecture Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.		●	●
v7	14.1 Segment the Network Based on Sensitivity Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).		●	●

6.5 Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server (Automated)

Profile Applicability:

- Level 1

Description:

Enable `connection_throttling` on `PostgreSQL flexible servers`.

Rationale:

Enabling `connection_throttling` helps the PostgreSQL Database to `Set the verbosity of logged messages`. This in turn generates query and error logs with respect to concurrent connections that could lead to a successful Denial of Service (DoS) attack by exhausting connection resources. A system can also fail or be degraded by an overload of legitimate users. Query and error logs can be used to identify, troubleshoot, and repair configuration errors and sub-optimal performance.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `connection_throttle.enable`.
5. Ensure that `VALUE` for `connection_throttle.enable` is set to `ON`.

Audit from Azure CLI

Ensure the below command returns a `value` of `on`:

```
az postgres flexible-server parameter show --resource-group <resourceGroup> -
-server-name <serverName> --name connection_throttle.enable
```

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name connection_throttle.enable
```

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** dacf07fa-0eea-4486-80bc-b93fae88ac40 **- Name:** 'Connection throttling should be enabled for PostgreSQL flexible servers'

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `connection_throttle.enable`.
5. Set `connection_throttle.enable` to `ON`.
6. Click `Save`.

Remediate from Azure CLI

Use the below command to enable `connection_throttle.enable`:

```
az postgres flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name connection_throttle.enable --value on
```

Remediate from PowerShell

Use the below command to update `connection_throttling` configuration.

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name connection_throttle.enable -
Value on
```

Default Value:

By default, `connection_throttle.enable` is disabled (set to `off`).

References:

1. https://learn.microsoft.com/en-us/rest/api/postgresql/flexibleserver/configurations/list-by-server
2. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/how-to-configure-server-parameters-using-portal
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation

4. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/get-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-get-specified-postgresql-configuration-by-name
5. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/update-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-updatae-specified-postgresql-configuration-by-name

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1499	TA0040	M1037

6.6 Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server (Automated)

Profile Applicability:

- Level 1

Description:

Ensure `logfiles.retention_days` on `PostgreSQL flexible servers` is set to an appropriate value.

Rationale:

Configuring `logfiles.retention_days` determines the duration in days that `Azure Database for PostgreSQL` retains log files. Query and error logs can be used to identify, troubleshoot, and repair configuration errors and sub-optimal performance.

Impact:

Configuring this setting will result in logs being retained for the specified number of days. If this is configured on a high traffic server, the log may grow quickly to occupy a large amount of disk space. In this case you may want to set this to a lower number.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `logfiles.retention_days`.
5. Ensure that the `VALUE` is between 4 and 7 (inclusive).

Audit from Azure CLI

Ensure `logfiles.retention_days` value is greater than 3.

```
az postgres flexible-server parameter show --resource-group <resourceGroup> -
-server-name <serverName> --name logfiles.retention_days
```

Audit from Powershell

Ensure `logfiles.retention_days` value is greater than 3:

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name logfiles.retention_days
```

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `logfiles.retention_days`.
5. Input a value between 4 and 7 (inclusive).
6. Click `Save`.

Remediate from Azure CLI

Use the below command to update `logfiles.retention_days` configuration:

```
az postgres flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name logfiles.retention_days --value <4-7>
```

Remediate from Powershell

Use the below command to update `logfiles.retention_days` configuration:

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name logfiles.retention_days -Value
<4-7>
```

Default Value:

By default `logfiles.retention_days` is set to `3`.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/how-to-configure-server-parameters-using-portal
2. https://learn.microsoft.com/en-us/rest/api/postgresql/flexibleserver/configurations/list-by-server
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-6-configure-log-storage-retention
4. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/get-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-get-specified-postgresql-configuration-by-name
5. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/update-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-updatae-specified-postgresql-configuration-by-name

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1485	TA0040	M1053

6.7 Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server (Automated)

Profile Applicability:

- Level 1

Description:

Enable `log_checkpoints` on `PostgreSQL flexible servers`.

Rationale:

Enabling `log_checkpoints` helps the PostgreSQL Database to `Log each checkpoint`, which in turn generates query and error logs. However, access to transaction logs is not supported. Query and error logs can be used to identify, troubleshoot, and repair configuration errors and sub-optimal performance.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `log_checkpoints`.
5. Ensure that the `VALUE` for `log_checkpoints` is set to `ON`.

Audit from Azure CLI

Ensure the below command returns a `value` of `on`:

```
az postgres flexible-server parameter show --resource-group <resourceGroup> -
-server-name <serverName> --name log_checkpoints
```

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name log_checkpoints
```

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 70be9e12-c935-49ac-9bd8-fd64b85c1f87 **- Name:** 'Log checkpoints should be enabled for PostgreSQL flexible servers'

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `log_checkpoints`.
5. Set the `VALUE` for `log_checkpoints` to `ON`.
6. Click `Save`.

Remediate from Azure CLI

Use the below command to enable `log_checkpoints`:

```
az postgres flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name log_checkpoints --value on
```

Remediate from PowerShell

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name log_checkpoints -Value on
```

Default Value:

By default `log_checkpoints` is enabled (set to `on`).

References:

1. https://learn.microsoft.com/en-us/rest/api/postgresql/flexibleserver/configurations/list-by-server
2. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/how-to-configure-server-parameters-using-portal
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation
4. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/concepts-logging#configure-logging

5. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/get-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-get-specified-postgresql-configuration-by-name
6. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/update-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-updatae-specified-postgresql-configuration-by-name

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1485	TA0040	M1053

6.8 Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers (Automated)

Profile Applicability:

- Level 1

Description:

Enable `log_disconnections` on PostgreSQL servers.

Rationale:

Enabling `log_disconnections` helps PostgreSQL Database to `Logs end of a session`, including duration, which in turn generates query and error logs. Query and error logs can be used to identify, troubleshoot, and repair configuration errors and sub-optimal performance.

Impact:

Enabling this setting will enable a log of all disconnections. If this is enabled for a high traffic server, the log may grow exponentially.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. Search for `log_disconnections`.
5. Ensure that `log_disconnections` is set to `ON`.

Audit from Azure CLI

Ensure `log_disconnections` value is set to `ON`

```
az postgres flexible-server parameter show --resource-group
<resourceGroupName> --server-name <serverName> --name log_disconnections
```

Audit from PowerShell

Ensure `log_disconnections` value is set to `ON`

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<ResourceGroupName> -ServerName <ServerName> -Name log_disconnections
```

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 1d14b021-1bae-4f93-b36b-69695e14984a **- Name:** 'Disconnections should be logged for PostgreSQL flexible servers'

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. Search for `log_disconnections`.
5. Set `log_disconnections` to `ON`.
6. Click `Save`.

Remediate from Azure CLI

Use the below command to update `log_disconnections` configuration.

```
az postgres flexible-server parameter set --resource-group
<resourceGroupName> --server-name <serverName> --name log_disconnections --
value on
```

Remediate from PowerShell

Use the below command to update `log_disconnections` configuration.

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<ResourceGroupName> -ServerName <ServerName> -Name log_disconnections -Value
on
```

Default Value:

By default `log_disconnections` is disabled (set to `off`).

References:

1. https://docs.microsoft.com/en-us/rest/api/postgresql
2. https://docs.microsoft.com/en-us/azure/postgresql/howto-configure-server-parameters-using-portal
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation

4. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/get-azpostgresqlconfiguration?view=azps-9.2.0#example-2-get-specified-postgresql-configuration-by-name
5. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/update-azpostgresqlconfiguration?view=azps-9.2.0#example-1-update-postgresql-configuration-by-name

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1485	TA0040	M1053

6.9 Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers (Automated)

Profile Applicability:

- Level 1

Description:

Enable `log_connections` on PostgreSQL servers.

Rationale:

Enabling `log_connections` helps PostgreSQL Database to log attempted connection to the server, as well as successful completion of client authentication. Log data can be used to identify, troubleshoot, and repair configuration errors and suboptimal performance.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `log_connections`.
5. Ensure that `log_connections` is set to `ON`.

Audit from Azure CLI

Ensure the below command returns a `Value` of `on`:

```
az postgres flexible-server parameter show --resource-group <resourceGroup> -
-server-name <serverName> --name log_connections
```

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name log_connections
```

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 086709ac-11b5-478d-a893-9567a16d2ae3 **- Name:** 'Log connections should be enabled for PostgreSQL flexible servers'

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `log_connections`.
5. Set `log_connections` to `ON`.
6. Click `Save`.

Remediate from Azure CLI

Use the below command to update `log_connections` configuration.

```
az postgres flexible-server parameter set --resource-group
<resourceGroupName> --server-name <serverName> --name log_connections --value
on
```

Remediate from PowerShell

Use the below command to update `log_connections` configuration.

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<ResourceGroupName> -ServerName <ServerName> -Name log_connections -Value on
```

Default Value:

By default `log_connections` is disabled (set to `off`).

References:

1. https://docs.microsoft.com/en-us/rest/api/postgresql/configurations/listbyserver
2. https://docs.microsoft.com/en-us/azure/postgresql/howto-configure-server-parameters-using-portal
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation
4. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/get-azpostgresqlconfiguration?view=azps-9.2.0#example-2-get-specified-postgresql-configuration-by-name

5. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/update-azpostgresqlconfiguration?view=azps-9.2.0#example-1-update-postgresql-configuration-by-name

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1485	TA0040	M1053

6.10 Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server (Automated)

Profile Applicability:

- Level 1

Description:

Enable `require_secure_transport` on `PostgreSQL flexible servers`.

Rationale:

`SSL connectivity` helps to provide a new layer of security by connecting database server to client applications using Secure Sockets Layer (SSL). Enforcing SSL connections between database server and client applications helps protect against "man in the middle" attacks by encrypting the data stream between the server and application.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `require_secure_transport`.
5. Ensure that the `VALUE` for `require_secure_transport` is set to `ON`.

Audit from Azure CLI

Ensure the below command returns a `value` of `on`:

```
az postgres flexible-server parameter show --resource-group <resourceGroup> -
-server-name <serverName> --name require_secure_transport
```

Audit from PowerShell

Ensure the below command returns a `Value` of `on`:

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name require_secure_transport
```

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** c29c38cb-74a7-4505-9a06-e588ab86620a **- Name:** 'Enforce SSL connection should be enabled for PostgreSQL flexible servers'

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter bar, type `require_secure_transport`.
5. Set the `VALUE` for `require_secure_transport` to `ON`.
6. Click `Save`.

Remediate from Azure CLI

Use the below command to enable `require_secure_transport`:

```
az postgres flexible-server parameter set --resource-group <resourceGroup> --
server-name <serverName> --name require_secure_transport --value on
```

Remediate from PowerShell

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName
<resourceGroup> -ServerName <serverName> -Name require_secure_transport -
Value on
```

Default Value:

By default, secure connectivity is enforced, but some application frameworks may not enable it during deployment.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/concepts-networking-ssl-tls
2. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/how-to-connect-tls-ssl
3. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/get-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-get-specified-postgresql-configuration-by-name

4. https://learn.microsoft.com/en-us/powershell/module/az.postgresql/update-azpostgresqlflexibleserverconfiguration?view=azps-12.2.0#example-1-updatae-specified-postgresql-configuration-by-name
5. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-data-protection#dp-3-encrypt-sensitive-data-in-transit

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1040	TA0006, TA0007	M1041

6.11 Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server (Automated)

Profile Applicability:

- Level 1

Description:

Note: It is not possible to set the minimal TLS version on PostgreSQL flexible server to lower than 1.2. Incoming connections which try to encrypt the traffic using TLS 1.0 and TLS 1.1 are denied.

Setting 'ssl_min_protocol_version' to 'TLSv1.2' or higher reduces TLS protocol vulnerabilities by preventing the use of significantly outdated versions of TLS.

Rationale:

The Secure Sockets Layer (SSL) protocol encrypts network traffic transiting between server and client.

Using only the most recent versions of SSL protocols (TLS version 1.2 and higher) eliminates susceptibility to known exploited vulnerabilities of outdated versions of TLS. If TLS 1.2 does not provide additional granular configuration options for supported cipher suites, there's a chance that default ciphers which employ Cipher Block Chaining (CBC) mode may be enabled which would introduce Padding Oracle types of vulnerabilities. TLS 1.3 does not support CBC mode ciphers by default and by default supports GCM ciphers which include an extra authentication step during the clear text to cipher text encryption process.

TLS version 1.3 is preferable where it is possible to implement.

Versions 1.0 and 1.1 of TLS are no longer considered secure. These versions should not be used or permitted where data integrity and confidentiality are required.

Impact:

TLS 1.3 is not compatible with older versions, so must be supported by all clients to be implemented.

Cipher suites may be able to be specified for TLS 1.2 if a premium SKU is in use.

Audit:

Audit from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter box, type `ssl_min_protocol_version`.
5. Ensure `ssl_min_protocol_version` is set to `TLSV1.2` or higher.

6. Repeat steps 1-5 for each server.

Audit from Azure CLI

Run the following command to list PostgreSQL flexible servers:

```
az postgres flexible-server list
```

For each server, run the following command to get the `ssl_min_protocol_version` parameter value:

```
az postgres flexible-server parameter show --resource-group <resource-group>
--server-name <server> --name ssl_min_protocol_version --query value
```

Ensure `"TLSv1.2"` or higher is returned.

Audit from PowerShell

Run the following command to list PostgreSQL flexible servers:

```
Get-AzPostgreSqlFlexibleServer
```

For each server, run the following command to get the `ssl_min_protocol_version` parameter value:

```
Get-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName <resource-
group> -ServerName <server> -Name ssl_min_protocol_version | Select -p Value
```

Ensure `TLSv1.2` or higher is returned.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** a43d5475-c569-45ce-a268-28fa79f4e87a **- Name:** 'PostgreSQL flexible servers should be running TLS version 1.2 or newer'

Remediation:

Remediate from Azure Portal

1. Login to Azure Portal using https://portal.azure.com.
2. Go to `Azure Database for PostgreSQL servers`.
3. For each server, under `Settings`, click `Server parameters`.
4. In the filter box, type `ssl_min_protocol_version`.
5. Set `ssl_min_protocol_version` to `TLSV1.2` or higher.
6. Select `Save`.
7. Repeat steps 1-6 for each server requiring remediation.

Remediate from Azure CLI

For each server requiring remediation, run the following command to set `ssl_min_protocol_version` to `TLSv1.2` or higher:

```
az postgres flexible-server parameter set --resource-group <resource-group> -
-server-name <server> --name ssl_min_protocol_version --value TLSv1.2
```

Remediate from PowerShell

For each server requiring remediation, run the following command to set `ssl_min_protocol_version` to `TLSv1.2` or higher:

```
Update-AzPostgreSqlFlexibleServerConfiguration -ResourceGroupName <resource-
group> -ServerName <server> -Name ssl_min_protocol_version -Value TLSv1.2
```

Default Value:

By default, `ssl_min_protocol_version` is set to `TLSv1.2`.

References:

1. https://learn.microsoft.com/en-us/azure/postgresql/flexible-server/security-connect-tls
2. https://learn.microsoft.com/en-us/azure/postgresql/security/security-tls

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1040	TA0007	M1041

7 Azure Database Migration Service

No specific prescriptive guidance exists yet for Azure Database Migration Service.

While this Service is under community development, we strongly recommend reviewing the relevant descriptive guidance provided by the Microsoft Cloud Security Benchmark here: https://learn.microsoft.com/en-us/security/benchmark/azure/

Please note that while Benchmark prescriptive guidance does not yet exist for this service, there are likely considerations for secure configuration that may require your due care and due diligence. To determine which aspects of configuration are the responsibility of the customer, and which are assumed by Microsoft, we recommend reviewing Microsoft's Shared Responsibility Model: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Database Migration Service

Azure Product Page:

- https://azure.microsoft.com/en-us/products/database-migration/

Azure Database Migration Service overview:

- https://learn.microsoft.com/en-us/azure/dms/

Microsoft Cloud Security Baseline for Azure Database Migration Service:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-database-migration-service-security-baseline

8 Azure SQL (Reference)

Azure SQL is a family of Azure products for the Microsoft SQL Server database engine. For security best practice recommendations for this family of products, please use the brief descriptions below to reference the appropriate section of this Benchmark for the Azure SQL sub-product which is relevant to your environment:

- **Azure SQL Database - "SQL DB" - (Section 9):** A managed Platform as a Service (PaaS) implementation of SQL with a smaller set of the features than Azure SQL MI*.
- **Azure SQL Managed Instance - "SQL MI" - (Section 10):** A managed Platform as a Service (PaaS) implementation of SQL with a larger set of features than Azure SQL DB*.
- **SQL Server on Azure Virtual Machines (Section 11):** An implementation of SQL Server that relies on the use of a dedicated virtual machine.

*To better understand the feature differences between Azure SQL Database (SQL DB) and Azure SQL Managed Instance (SQL MI), please refer to this document: https://learn.microsoft.com/en-us/azure/azure-sql/database/features-comparison?view=azuresql

Azure Product Page: https://azure.microsoft.com/en-us/products/azure-sql/

9 Azure SQL Database

This section covers security best practice recommendations for Azure SQL Database.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure SQL Database Service

Azure Product Page:

- https://azure.microsoft.com/en-us/products/azure-sql/database/

Azure SQL Database service overview:

- https://learn.microsoft.com/en-us/azure/azure-sql/database/sql-database-paas-overview?view=azuresql

Microsoft Cloud Security Baseline for Azure SQL Database:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/azure-sql-security-baseline

9.1 Ensure that 'Auditing' is set to 'On' (Automated)

Profile Applicability:

- Level 1

Description:

Enable auditing on SQL Servers.

Rationale:

The Azure platform allows a SQL server to be created as a service. Enabling auditing at the server level ensures that all existing and newly created databases on the SQL server instance are audited. Auditing policy applied on the SQL database does not override auditing policy and settings applied on the particular SQL server where the database is hosted.

Auditing tracks database events and writes them to an audit log in the Azure storage account. It also helps to maintain regulatory compliance, understand database activity, and gain insight into discrepancies and anomalies that could indicate business concerns or suspected security violations.

Audit:

Audit From Azure Portal

1. Go to `SQL servers`
2. For each server instance
3. Click on `Auditing`
4. Ensure that `Enable Azure SQL Auditing` is set to `On`

Audit From PowerShell

Get the list of all SQL Servers

```
Get-AzSqlServer
```

For each Server

```
Get-AzSqlServerAudit -ResourceGroupName <ResourceGroupName> -ServerName
<SQLServerName>
```

Ensure that `BlobStorageTargetState`, `EventHubTargetState`, or `LogAnalyticsTargetState` is set to `Enabled`.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** a6fb4358-5bf4-4ad7-ba82-2cd2f41ce5e9 **- Name:** 'Auditing on SQL server should be enabled'

Remediation:

Remediate From Azure Portal

1. Go to `SQL servers`
2. Select the SQL server instance
3. Under `Security`, click `Auditing`
4. Click the toggle next to `Enable Azure SQL Auditing`
5. Select an Audit log destination
6. Click `Save`

Remediate From PowerShell

Get the list of all SQL Servers

```
Get-AzSqlServer
```

For each Server, enable auditing and set the retention for at least 90 days.

Log Analytics Example

```
Set-AzSqlServerAudit -ResourceGroupName <resource group name> -ServerName
<SQL Server name> -RetentionInDays <Number of Days to retain the audit logs,
should be 90days minimum> -LogAnalyticsTargetState Enabled -
WorkspaceResourceId "/subscriptions/<subscription
ID>/resourceGroups/insights-
integration/providers/Microsoft.OperationalInsights/workspaces/<workspace
name>
```

Event Hub Example

```
Set-AzSqlServerAudit -ResourceGroupName "<resource group name>" -ServerName
"<SQL Server name>" -EventHubTargetState Enabled -EventHubName
    "<Event Hub name>" -EventHubAuthorizationRuleResourceId "<Event Hub
Authorization Rule Resource ID>"
```

Blob Storage Example

```
Set-AzSqlServerAudit -ResourceGroupName "<resource group name>" -ServerName
"<SQL Server name>" -BlobStorageTargetState Enabled
    -StorageAccountResourceId
"/subscriptions/<subscription_ID>/resourceGroups/<Resource_Group>/providers/M
icrosoft.Stora
    ge/storageAccounts/<Storage Account name>"
```

Default Value:

By default, `Enable Azure SQL Auditing` is set to `Off`.

References:

1. https://docs.microsoft.com/en-us/azure/security-center/security-center-enable-auditing-on-sql-servers
2. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/get-azurermsqlserverauditing?view=azurermps-5.2.0
3. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/set-azurermsqlserverauditingpolicy?view=azurermps-5.2.0
4. https://docs.microsoft.com/en-us/azure/sql-database/sql-database-auditing
5. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-3-enable-logging-for-security-investigation

Additional Information:

- A server policy applies to all existing and newly created databases on the server.
- If server blob auditing is enabled, it always applies to the database. The database will be audited, regardless of the database auditing settings. Auditing type table is already deprecated leaving only type blob available.
- Enabling blob auditing on the database, in addition to enabling it on the server, does not override or change any of the settings of the server blob auditing. Both audits will exist side by side. In other words, the database is audited twice in parallel; once by the server policy and once by the database policy.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●

Controls Version	Control	IG 1	IG 2	IG 3
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1505.001	TA0040	M1047

9.2 Ensure that 'Public Network Access' is set to 'Disable' (Automated)

Profile Applicability:

- Level 2

Description:

Disabling public network access restricts the service from accessing public networks.

Rationale:

A secure network architecture requires carefully constructed network segmentation. Public network access is overly permissive and introduces unintended vectors for threat activity.

Impact:

Disabling 'Public Network Access' forces the requirement of the use of Private Endpoints for network connectivity which will require some additional consideration from a network architecture perspective and will introduce cost based on the inbound/outbound data being processed by the Private Endpoint.

Audit:

From Azure Portal

1. Go to `SQL servers`.
2. For each SQL server, under `Security`, click `Networking`.
3. Ensure that `Public network access` is set to `Disable`.

From Azure CLI

List all SQL Servers and ensure `publicNetworkAccess` is **not** `Enabled`:

```
az sql server list --query "[].{name:name, resourceGroup:resourceGroup,
publicNetworkAccess:publicNetworkAccess}"
```

From PowerShell

List all SQL Servers and ensure `PublicNetworkAccess` is **not** `Enabled`:

```
Get-AzSqlServer | Select-Object -Property ServerName, ResourceGroupName,
PublicNetworkAccess
```

Audit from Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 1b8ca024-1d5c-4dec-8995-b1a932b41780 - **Name:** 'Public network access on Azure SQL Database should be disabled'

Remediation:

From Azure Portal

1. Go to `SQL servers`.
2. For each SQL server, under `Security`, click `Networking`.
3. Set `Public network access` to `Disable`.
4. Click `Save`.

From Azure CLI

For each SQL server with `publicNetworkAccess Enabled`, set it to `Disabled`:

```
az sql server update -n <sqlServerName> -g <resourceGroup> --set
publicNetworkAccess="Disabled"
```

From PowerShell

For each SQL server with `PublicNetworkAccess Enabled`, set it to `Disabled`:

```
Set-AzSqlServer -ServerName <sqlServerName> -ResourceGroupName
<resourceGroup> -PublicNetworkAccess "Disabled"
```

Default Value:

By default, Azure SQL Server's public network access is set to `Disable`.

References:

1. https://learn.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-network-security#ns-2-secure-cloud-services-with-network-controls
2. https://learn.microsoft.com/en-us/azure/azure-sql/database/connectivity-settings?view=azuresql&tabs=azure-portal#deny-public-network-access

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

9.3 Ensure no Azure SQL Database firewall rule is overly permissive (Automated)

Profile Applicability:

- Level 1

Description:

Ensure that no SQL Databases have overly permissive firewall rules (e.g. rule allowing traffic with start IP address of 0.0.0.0 and end IP address of 255.255.255.255, or other combinations allowing large swathes of IP addresses).

Rationale:

The preferred setting for Public Network Access is disabled. If Public Network Access is disabled, this recommendation is moot. In general, the use of well architected Private Endpoints for network traffic management is strongly preferred to allowing any public network access.

Where Public Network Access must be allowed as an exception, Azure SQL Server provides a firewall to explicitly define traffic allowance and denial. In order to reduce the potential attack surface for a SQL server, firewall rules should be reviewed from time to time to ensure that no rule is overly permissive, and all included rules are justified through association with known and trusted sources and destinations.

NOTE: For some Azure services to work with Azure SQL databases, the `Allow Azure services and resource to access this server` exception may need to be allowed. This exception creates a firewall rule named `AllowAllWindowsAzureIps` that may be considered overly permissive. It should be noted that this exception places implicit trust on a rule which is defined and managed by Microsoft. This rule can be viewed in the SQL database's master database under `sys.firewall_rules` (more details here: https://learn.microsoft.com/en-us/sql/relational-databases/system-catalog-views/sys-firewall-rules-azure-sql-database?view=azuresqldb-current).

Impact:

Managing firewall rules will require some consideration from a network architecture perspective to ensure appropriate traffic is allowed.

Audit:

Audit from Azure Portal

1. Search for and open `SQL servers`
2. For each SQL server listed, click on the server name to open the resource management window
3. Expand the Security section, then click on `Networking`

4. On the 'Public access' tab, if public network access is set to "Selected Networks," scroll down to review the `Firewall rules`

Ensure that no firewall rule exists which allows traffic with a source of `0.0.0.0` or other combinations which permit access to/from wider public IP ranges.

Audit from Azure CLI

List all SQL servers

```
az sql server list
```

For each SQL server run the following command

```
az sql server firewall-rule list --resource-group <resource group name> --
server <sql server name>
```

Ensure the output does not contain any firewall `allow` rules with a source of `0.0.0.0` or other combinations which allows access to wider public IP ranges

Audit from PowerShell

Get the list of all SQL Servers

```
Get-AzSqlServer
```

For each Server

```
Get-AzSqlServerFirewallRule -ResourceGroupName <resource group name> -
ServerName <server name>
```

Ensure that `StartIpAddress` is not set to `0.0.0.0`, `/0` or other combinations which allows access to wider public IP ranges including Azure IP ranges.

Remediation:

Remediate from Azure Portal

1. Search for and open `SQL servers`
2. For each SQL server listed, click on the server name to open the resource management window
3. Expand the Security section, then click on `Networking`
4. On the 'Public access' tab, if public network access is set to "Selected Networks," scroll down to the Firewall Rules section
5. Remove overly permissive firewall rules and ensure that any remaining rules contain only source and destination IPs which are trusted.

Remediate from Azure CLI

Identify the resource group, server name, and firewall rule name which are overly permissive, then delete the identified rule with the following command:

```
az sql server firewall-rule delete --resource-group <resource_group> --server
<sql_server_name> --name <firewall_rule_name>
```

For trusted IP addresses, use these commands to create or updates rules as needed:

Create a firewall rule:

```
az sql server firewall-rule create --resource-group <resource_group> --server
<sql_server_name> --name <firewall_rule_name> --start-ip-address "<IP Address
other than 0.0.0.0>" --end-ip-address "<IP Address other than 0.0.0.0 or
255.255.255.255>"
```

Update a firewall rule:

```
az sql server firewall-rule update --resource-group <resource_group> --server
<sql_server_name> --name <firewall_rule_name> --start-ip-address "<IP Address
other than 0.0.0.0>" --end-ip-address "<IP Address other than 0.0.0.0 or
255.255.255.255>"
```

Remediate from PowerShell

Identify the resource group, server name, and firewall rule name which are overly permissive, then delete the identified rule with the following command:

```
Remove-AzSqlServerFirewallRule -FirewallRuleName "<firewall_rule_name>" -
ResourceGroupName <resource_group_name> -ServerName <server_name>
```

For trusted IP addresses, use these commands to create or updates rules as needed:

```
Set-AzSqlServerFirewallRule -ResourceGroupName <resource_group_name> -
ServerName <server_name> -FirewallRuleName "<firewall_rule_name>" -
StartIpAddress "<IP Address other than 0.0.0.0>" -EndIpAddress "<IP Address
other than 0.0.0.0 or 255.255.255.255>"
```

Default Value:

By default, no firewall rules exist.

References:

1. https://docs.microsoft.com/en-us/sql/database-engine/configure-windows/configure-a-windows-firewall-for-database-engine-access?view=sql-server-2017
2. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/get-azurermsqlserverfirewallrule?view=azurermps-5.2.0
3. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/set-azurermsqlserverfirewallrule?view=azurermps-5.2.0
4. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/remove-azurermsqlserverfirewallrule?view=azurermps-5.2.0
5. https://learn.microsoft.com/en-us/azure/azure-sql/database/firewall-configure?view=azuresql#connections-from-inside-azure
6. https://docs.microsoft.com/en-us/sql/relational-databases/system-stored-procedures/sp-set-database-firewall-rule-azure-sql-database?view=azuresqldb-current
7. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-network-security#ns-2-secure-cloud-native-services-with-network-controls

8. https://learn.microsoft.com/en-us/azure/azure-sql/database/firewall-configure?view=azuresql

Additional Information:

Firewall rules configured on individual SQL Database using Transact-SQL overrides the rules set on SQL server. Azure does not provide any PowerShell, API, CLI, Portal option to check database level firewall rules, and so far Transact-SQL is the only way to check. For comprehensive control over ingress traffic on SQL Databases, firewall rules should be checked using a SQL client.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1190	TA0001	M1050

9.4 Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key (Automated)

Profile Applicability:

- Level 2

Description:

Transparent Data Encryption (TDE) with Customer-managed key support provides increased transparency and control over the TDE Protector, increased security with an HSM-backed external service, and promotion of separation of duties.

With TDE, data is encrypted at rest with a symmetric key (called the database encryption key) stored in the database or data warehouse distribution. To protect this data encryption key (DEK) in the past, only a certificate that the Azure SQL Service managed could be used. Now, with Customer-managed key support for TDE, the DEK can be protected with an asymmetric key that is stored in the Azure Key Vault. The Azure Key Vault is a highly available and scalable cloud-based key store which offers central key management, leverages FIPS 140-2 Level 2 validated hardware security modules (HSMs), and allows separation of management of keys and data for additional security.

Based on business needs or criticality of data/databases hosted on a SQL server, it is recommended that the TDE protector is encrypted by a key that is managed by the data owner (Customer-managed key).

Rationale:

Customer-managed key support for Transparent Data Encryption (TDE) allows user control of TDE encryption keys and restricts who can access them and when. Azure Key Vault, Azure’s cloud-based external key management system, is the first key management service where TDE has integrated support for Customer-managed keys. With Customer-managed key support, the database encryption key is protected by an asymmetric key stored in the Key Vault. The asymmetric key is set at the server level and inherited by all databases under that server.

Impact:

Once TDE protector is encrypted with a Customer-managed key, it transfers entire responsibility of respective key management on to you, and hence you should be more careful about doing any operations on the particular key in order to keep data from corresponding SQL server and Databases hosted accessible.

When deploying Customer Managed Keys, it is prudent to ensure that you also deploy an automated toolset for managing these keys (this should include discovery and key rotation), and Keys should be stored in an HSM or hardware backed keystore, such as Azure Key Vault.

As far as toolsets go, check with your cryptographic key provider, as they may well provide one as an add-on to their service.

Audit:

Audit From Azure Portal

1. Go to `SQL servers`

For the desired server instance

2. Click On `Transparent data encryption`
3. Ensure that `Customer-managed key` is selected
4. Ensure `Make selected key the default TDE protector` is checked

Audit From Azure CLI

```
az account get-access-token --query
"{subscripton:subscription,accessToken:accessToken}" --out tsv | xargs -L1
bash -c 'curl -X GET -H "Authorization: Bearer $1" -H "Content-Type:
application/json"
https://management.azure.com/subscriptions/$0/resourceGroups/{resourceGroupNa
me}/providers/Microsoft.Sql/servers/{serverName}/encryptionProtector?api-
version=2015-05-01-preview'
```

Ensure the output of the command contains properties

`kind` set to `azurekeyvault`

`serverKeyType` set to `AzureKeyVault`

`uri` is not null

Audit From PowerShell

```
Get-AzSqlServerTransparentDataEncryptionProtector -ServerName <ServerName> -
ResourceGroupName <ResourceGroupName>
```

Ensure the output of the command contains properties

`Type` set to `AzureKeyVault`

`ServerKeyVaultKeyName` set to `KeyVaultName_KeyName_KeyIdentifierVersion`

`KeyId` set to `KeyIdentifier`

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 0a370ff3-6cab-4e85-8995-295fd854c5b8 **- Name:** 'SQL servers should use customer-managed keys to encrypt data at rest'
- **Policy ID:** ac01ad65-10e5-46df-bdd9-6b0cad13e1d2 **- Name:** 'SQL managed instances should use customer-managed keys to encrypt data at rest'

Remediation:

Remediate From Azure Console

1. Go to `SQL servers`

For the desired server instance

2. Click On `Transparent data encryption`
3. Set `Transparent data encryption` to `Customer-managed key`
4. Browse through your `key vaults` to Select an existing key or create a new key in the Azure Key Vault.
5. Check `Make selected key the default TDE protector`

Remediate From Azure CLI

Use the below command to encrypt SQL server's TDE protector with a Customer-managed key

```
az sql server tde-key set --resource-group <resourceName> --server
<dbServerName> --server-key-type {AzureKeyVault} --kid <keyIdentifier>
```

Remediate From PowerShell

Use the below command to encrypt SQL server's TDE protector with a Customer-managed Key Vault key

```
Set-AzSqlServerTransparentDataEncryptionProtector -Type AzureKeyVault -KeyId
<KeyIdentifier> -ServerName <ServerName> -ResourceGroupName
<ResourceGroupName>
```

Select `Y` when prompted

Default Value:

By Default, Microsoft managed TDE protector is enabled for a SQL server.

References:

1. https://docs.microsoft.com/en-us/sql/relational-databases/security/encryption/transparent-data-encryption-byok-azure-sql
2. https://azure.microsoft.com/en-in/blog/preview-sql-transparent-data-encryption-tde-with-bring-your-own-key-support/
3. https://winterdom.com/2017/09/07/azure-sql-tde-protector-keyvault
4. https://docs.microsoft.com/en-us/security/benchmark/azure/security-controls-v3-data-protection#dp-5-use-customer-managed-key-option-in-data-at-rest-encryption-when-required
5. https://docs.microsoft.com/en-us/azure/key-vault/general/basic-concepts
6. https://docs.microsoft.com/en-us/cli/azure/sql/server/tde-key?view=azure-cli-latest
7. https://learn.microsoft.com/en-us/powershell/module/az.sql/get-azsqlservertransparentdataencryptionprotector?view=azps-9.2.0
8. https://learn.microsoft.com/en-us/powershell/module/az.sql/set-azsqlservertransparentdataencryptionprotector?view=azps-9.2.0

Additional Information:

- This configuration is audited or can be done only on SQL server. The same configuration will be in effect on SQL Databases hosted on SQL Server.
- Ensuring TDE is protected by a Customer-managed key on SQL Server does not ensure the encryption of SQL Databases. `Transparent Data Encryption : Data Encryption (ON/OFF)` setting on individual SQL Database decides whether database is encrypted or not.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1530	TA0009	M1041

9.5 Ensure that Microsoft Entra authentication is Configured for SQL Servers (Automated)

Profile Applicability:

- Level 1

Description:

Use Microsoft Entra authentication for authentication with SQL Database to manage credentials in a single place.

Rationale:

Microsoft Entra authentication is a mechanism to connect to Microsoft Azure SQL Database and SQL Data Warehouse by using identities in the Microsoft Entra ID directory. With Entra ID authentication, identities of database users and other Microsoft services can be managed in one central location. Central ID management provides a single place to manage database users and simplifies permission management.

- It provides an alternative to SQL Server authentication.
- Helps stop the proliferation of user identities across database servers.
- Allows password rotation in a single place.
- Customers can manage database permissions using external (Entra ID) groups.
- It can eliminate storing passwords by enabling integrated Windows authentication and other forms of authentication supported by Microsoft Entra.
- Entra ID authentication uses contained database users to authenticate identities at the database level.
- Entra ID supports token-based authentication for applications connecting to SQL Database.
- Entra ID authentication supports ADFS (domain federation) or native user/password authentication for a local Active Directory without domain synchronization.
- Entra ID supports connections from SQL Server Management Studio that use Active Directory Universal Authentication, which includes Multi-Factor Authentication (MFA). MFA includes strong authentication with a range of easy verification options — phone call, text message, smart cards with pin, or mobile app notification.

Impact:

This will create administrative overhead with user account and permission management. For further security on these administrative accounts, you may want to consider licensing which supports features like Multi Factor Authentication.

Audit:

Audit From Azure Portal

1. Go to `SQL servers`
2. For each SQL server, click on `Microsoft Entra admin` under the Settings section
3. Ensure that a value has been set for `Admin Name` under the `Microsoft Entra admin` section

Audit From Azure CLI

To list SQL Server Admins on a specific server:

```
az sql server ad-admin list --resource-group <resource-group> --server
<server>
```

Audit From PowerShell

Print a list of all SQL Servers to find which one you want to audit

```
Get-AzSqlServer
```

Audit a list of Administrators on a Specific Server

```
Get-AzSqlServerActiveDirectoryAdministrator -ResourceGroupName <resource
group name> -ServerName <server name>
```

Ensure Output shows `DisplayName` set to `AD account`.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 1f314764-cb73-4fc9-b863-8eca98ac36e9 **- Name:** 'An Azure Active Directory administrator should be provisioned for SQL servers'

Remediation:

Remediate From Azure Portal

1. Go to `SQL servers`
2. For each SQL server, click on `Microsoft Entra admin`
3. Click on `Set admin`
4. Select an admin
5. Click `Save`

Remediate From Azure CLI

```
az ad user show --id
```

For each Server, set AD Admin

```
az sql server ad-admin create --resource-group <resource group name> --server
<server name> --display-name <display name> --object-id <object id of user>
```

Remediate From PowerShell

For each Server, set Entra ID Admin

```
Set-AzSqlServerActiveDirectoryAdministrator -ResourceGroupName <resource
group name> -ServerName <server name> -DisplayName "<Display name of AD
account to set as DB administrator>"
```

Default Value:

Entra ID Authentication for SQL Database/Server is not enabled by default

References:

1. https://learn.microsoft.com/en-us/azure/azure-sql/database/authentication-aad-configure
2. https://docs.microsoft.com/en-us/azure/sql-database/sql-database-aad-authentication
3. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/get-azurermsqlserveractivedirectoryadministrator?view=azurermps-5.2.0
4. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-identity-management#im-1-use-centralized-identity-and-authentication-system
5. https://docs.microsoft.com/en-us/cli/azure/sql/server/ad-admin?view=azure-cli-latest#az_sql_server_ad_admin_list

Additional Information:

NOTE - Assigning an Administrator in Entra ID is just the first step. When using Entra ID for central authentication there are many other groups and roles that need to be configured base on the needs of your organization. The How-to Guides should be used to determine what roles should be assigned and what groups should be created to manage permissions and access to resources.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 Centralize Account Management Centralize account management through a directory or identity service.		●	●

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1078.004	TA0001	M1018

9.6 Ensure that 'Data encryption' is set to 'On' on a SQL Database (Automated)

Profile Applicability:

- Level 1

Description:

Enable Transparent Data Encryption on every SQL server.

Rationale:

Azure SQL Database transparent data encryption helps protect against the threat of malicious activity by performing real-time encryption and decryption of the database, associated backups, and transaction log files at rest without requiring changes to the application.

Audit:

Audit From Azure Portal

1. Go to `SQL databases`
2. For each DB instance
3. Click on `Transparent data encryption`
4. Ensure that `Data encryption` is set to `On`

Audit From Azure CLI

Ensure the output of the below command is `Enabled`

```
az sql db tde show --resource-group <resourceGroup> --server <dbServerName> -
-database <dbName> --query status
```

Audit From PowerShell

Get a list of SQL Servers.

```
Get-AzSqlServer
```

For each server, list the databases.

```
Get-AzSqlDatabase -ServerName <SQL Server Name> -ResourceGroupName <Resource
Group Name>
```

For each database not listed as a `Master` database, check for Transparent Data Encryption.

```
Get-AzSqlDatabaseTransparentDataEncryption -ResourceGroupName <Resource Group
Name> -ServerName <SQL Server Name> -DatabaseName <Database Name>
```

Make sure `DataEncryption` is `Enabled` for each database except the `Master` database.

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 17k78e20-9358-41c9-923c-fb736d382a12 **- Name:** 'Transparent Data Encryption on SQL databases should be enabled'

Remediation:

Remediate From Azure Portal

1. Go to `SQL databases`
2. For each DB instance
3. Click on `Transparent data encryption`
4. Set `Data encryption` to `On`

Remediate From Azure CLI

Use the below command to enable `Transparent data encryption` for SQL DB instance.

```
az sql db tde set --resource-group <resourceGroup> --server <dbServerName> --
database <dbName> --status Enabled
```

Remediate From PowerShell

Use the below command to enable `Transparent data encryption` for SQL DB instance.

```
Set-AzSqlDatabaseTransparentDataEncryption -ResourceGroupName <Resource Group
Name> -ServerName <SQL Server Name> -DatabaseName <Database Name> -State
'Enabled'
```

Note:

- TDE cannot be used to encrypt the logical master database in SQL Database. The master database contains objects that are needed to perform the TDE operations on the user databases.
- Azure Portal does not show master databases per SQL server. However, CLI/API responses will show master databases.

Default Value:

By default, `Data encryption` is set to `On`.

References:

1. https://docs.microsoft.com/en-us/sql/relational-databases/security/encryption/transparent-data-encryption-with-azure-sql-database
2. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-data-protection#dp-4-enable-data-at-rest-encryption-by-default
3. https://learn.microsoft.com/en-us/powershell/module/az.sql/set-azsqldatabasetransparentdataencryption?view=azps-9.2.0

Additional Information:

- Transparent Data Encryption (TDE) can be enabled or disabled on individual `SQL Database` level and not on the `SQL Server` level.
- TDE cannot be used to encrypt the logical master database in SQL Database. The master database contains objects that are needed to perform the TDE operations on the user databases.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	14.8 Encrypt Sensitive Information at Rest Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1530	TA0009	M1041

9.7 Ensure that 'Auditing' Retention is 'greater than 90 days' (Automated)

Profile Applicability:

- Level 1

Description:

SQL Server Audit Retention should be configured to be greater than 90 days.

Rationale:

Audit Logs can be used to check for anomalies and give insight into suspected breaches or misuse of information and access.

Audit:

Audit From Azure Portal

1. Go to `SQL servers`
2. For each server instance
3. Click on `Auditing`
4. If storage is selected, expand `Advanced properties`
5. Ensure `Retention (days)` setting is greater than `90` days or `0` for unlimited retention.

Audit From PowerShell

Get the list of all SQL Servers

```
Get-AzSqlServer
```

For each Server

```
Get-AzSqlServerAudit -ResourceGroupName <resource group name> -ServerName
<server name>
```

Ensure that `RetentionInDays` is set to `more than 90`

Note: If the SQL server is set with `LogAnalyticsTargetState` setting set to `Enabled`, run the following additional command.

```
Get-AzOperationalInsightsWorkspace | Where-Object {$_.ResourceId -eq <SQL
Server WorkSpaceResourceId>}
```

Ensure that `RetentionInDays` is set to `more than 90`

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 89099bee-89e0-4b26-a5f4-165451757743 **- Name:** 'SQL servers with auditing to storage account destination should be configured with 90 days retention or higher'

Remediation:

Remediate From Azure Portal

1. Go to `SQL servers`
2. For each server instance
3. Click on `Auditing`
4. If storage is selected, expand `Advanced properties`
5. Set the `Retention (days)` setting greater than `90` days or `0` for unlimited retention.
6. Select `Save`

Remediate From PowerShell For each Server, set retention policy to more than 90 days

Log Analytics Example

```
Set-AzSqlServerAudit -ResourceGroupName <resource group name> -ServerName
<SQL Server name> -RetentionInDays <Number of Days to retain the audit logs,
should be more than 90 days> -LogAnalyticsTargetState Enabled -
WorkspaceResourceId "/subscriptions/<subscription
ID>/resourceGroups/insights-
integration/providers/Microsoft.OperationalInsights/workspaces/<workspace
name>
```

Event Hub Example

```
Set-AzSqlServerAudit -ResourceGroupName "<resource group name>" -ServerName
"<SQL Server name>" -EventHubTargetState Enabled -EventHubName
    "<Event Hub name>" -EventHubAuthorizationRuleResourceId "<Event Hub
Authorization Rule Resource ID>"
```

Blob Storage Example

```
Set-AzSqlServerAudit -ResourceGroupName "<resource group name>" -ServerName
"<SQL Server name>" -BlobStorageTargetState Enabled
    -StorageAccountResourceId
"/subscriptions/<subscription_ID>/resourceGroups/<Resource_Group>/providers/M
icrosoft.Storage/storageAccounts/<Storage Account name>"
```

Default Value:

By default, SQL Server audit storage is `disabled`.

References:

1. https://docs.microsoft.com/en-us/azure/sql-database/sql-database-auditing
2. https://docs.microsoft.com/en-us/powershell/module/azurerm.sql/get-azurermsqlserverauditing?view=azurermps-5.2.0
3. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-logging-threat-detection#lt-6-configure-log-storage-retention

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

9.8 Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher (Automated)

Profile Applicability:

- Level 1

Description:

Note: It is no longer possible to set the minimal TLS version of SQL server to lower than 1.2. Azure ended support for TLS 1.0 and 1.1 in August 2025.

Setting the 'Minimum TLS version' to 'TLS 1.2' or higher reduces TLS protocol vulnerabilities by preventing the use of significantly outdated versions of TLS.

Rationale:

The Secure Sockets Layer (SSL) protocol encrypts network traffic transiting between server and client.

Using only the most recent versions of SSL protocols (TLS version 1.2 and higher) eliminates susceptibility to known exploited vulnerabilities of outdated versions of TLS. If TLS 1.2 does not provide additional granular configuration options for supported cipher suites, there's a chance that default ciphers which employ Cipher Block Chaining (CBC) mode may be enabled which would introduce Padding Oracle types of vulnerabilities. TLS 1.3 does not support CBC mode ciphers by default and by default supports GCM ciphers which include an extra authentication step during the clear text to cipher text encryption process.

TLS version 1.3 is preferable where it is possible to implement.

Versions 1.0 and 1.1 of TLS are no longer considered secure. These versions should not be used or permitted where data integrity and confidentiality are required.

Impact:

No impact to cost or performance.

Audit:

Audit from Azure Portal

1. Go to `SQL servers`.
2. Select the name of a SQL server.
3. Under `Security`, select `Networking`.
4. Select `Connectivity`.
5. Under `Encryption in transit`, ensure `Minimum TLS version` is set to `TLS 1.2` or higher.
6. Repeat steps 1-5 for each SQL server.

Audit from Azure CLI

Run the following command to list SQL servers:

```
az sql server list
```

For each SQL server, run the following command to get the `minimalTlsVersion` setting:

```
az sql server show --resource-group <resource-group> --name <sql-server> --
query minimalTlsVersion
```

Ensure `"1.2"` or higher is returned.

Audit from PowerShell

Run the following command to list SQL servers:

```
Get-AzSqlServer
```

Run the following command to get the server in a resource group with a given name:

```
$server = Get-AzSqlServer -ResourceGroupName <resource-group> -ServerName
<sql-server>
```

Run the following command to get the `MinimalTlsVersion`:

```
$server.MinimalTlsVersion
```

Ensure `1.2` or higher is returned.

Repeat for each SQL server

Audit From Azure Policy

If referencing a digital copy of this Benchmark, clicking a Policy ID will open a link to the associated Policy definition in Azure.

If referencing a printed copy, you can search Policy IDs from this URL: https://portal.azure.com/#view/Microsoft_Azure_Policy/PolicyMenuBlade/~/Definitions

- **Policy ID:** 32e6bbec-16b6-44c2-be37-c5b672d103cf **- Name:** 'Azure SQL Database should be running TLS version 1.2 or newer'

Remediation:

Remediate from Azure Portal

1. Go to `SQL servers`.
2. Select the name of a SQL server.
3. Under `Security`, select `Networking`.
4. Select `Connectivity`.
5. Under `Encryption in transit`, select `TLS 1.2` or higher from the dropdown menu next to `Minimum TLS version`.
6. Select `Save`.
7. Repeat steps 1-6 for each SQL server requiring remediation.

Remediate from Azure CLI

For each SQL server requiring remediation, run the following command to set `minimalTlsVersion` to `1.2` or higher:

```
az sql server update --resource-group <resource-group> --name <sql-server> --
minimal-tls-version 1.2
```

Remediate from PowerShell

For each SQL server requiring remediation, run the following command to set `MinimalTlsVersion` to `1.2` or higher:

```
Set-AzSqlServer -ServerName <sql-server> -ResourceGroupName <resource-group>
-MinimalTlsVersion 1.2
```

Default Value:

TLS 1.2 is the default setting for SQL server.

References:

1. https://learn.microsoft.com/en-us/azure/azure-sql/database/connectivity-settings?view=azuresql&tabs=azure-portal#minimum-tls-version

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

MITRE ATT&CK Mappings:

Techniques / Sub-techniques	Tactics	Mitigations
T1040	TA0007	M1041

10 Azure SQL Managed Instance

No specific prescriptive guidance exists yet for Azure SQL Managed Instance.

While this Service is under community development, we strongly recommend reviewing the relevant descriptive guidance provided by the Microsoft Cloud Security Benchmark here: https://learn.microsoft.com/en-us/security/benchmark/azure/

Please note that while Benchmark prescriptive guidance does not yet exist for this service, there are likely considerations for secure configuration that may require your due care and due diligence. To determine which aspects of configuration are the responsibility of the customer, and which are assumed by Microsoft, we recommend reviewing Microsoft's Shared Responsibility Model: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure SQL Managed Instance

Azure Product Page:

- https://azure.microsoft.com/en-us/products/azure-sql/managed-instance/

Azure SQL Managed Instance service overview:

- https://learn.microsoft.com/en-us/azure/azure-sql/managed-instance/sql-managed-instance-paas-overview?view=azuresql

11 SQL Server on Azure Virtual Machines

No specific prescriptive guidance exists yet for SQL Server on Azure Virtual Machines.

While this Service is under community development, we strongly recommend reviewing the relevant descriptive guidance provided by the Microsoft Cloud Security Benchmark here: https://learn.microsoft.com/en-us/security/benchmark/azure/

Please note that while Benchmark prescriptive guidance does not yet exist for this service, there are likely considerations for secure configuration that may require your due care and due diligence. To determine which aspects of configuration are the responsibility of the customer, and which are assumed by Microsoft, we recommend reviewing Microsoft's Shared Responsibility Model: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for SQL Server on Azure Virtual Machines

Azure Product Page:

- https://azure.microsoft.com/en-us/products/virtual-machines/sql-server/

SQL Server on Azure Virtual Machines service overview:

- https://learn.microsoft.com/en-us/azure/azure-sql/virtual-machines/windows/sql-server-on-azure-vm-iaas-what-is-overview?view=azuresql

Microsoft Cloud Security Baseline for SQL Server on Azure Virtual Machines:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/sql-iaas-security-baseline

12 Table Storage (Reference)

Coverage Location:

- Benchmark: "CIS Microsoft Azure **Storage Services** Benchmark"
- Section: **Azure Storage Accounts**

Table Storage in Azure is a sub-service of an Azure Storage Account. Security Best Practice recommendations improving the security of Table Storage are applied to the Azure Storage Account that is hosting the Table Storage, not configurable within the Table Storage sub-service. These recommendations will therefore be maintained in the "Storage Account" section of the CIS Microsoft Azure Storage Services Benchmark.

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Table Storage

Azure Product Page:

- https://azure.microsoft.com/en-us/products/storage/tables/

Azure Table Storage service overview:

- https://learn.microsoft.com/en-us/azure/storage/tables/table-storage-overview

13 Azure Managed Instance for Apache Cassandra

No specific prescriptive guidance exists yet for Azure Managed Instance for Apache Cassandra.

While this Service is under community development, we strongly recommend reviewing the relevant descriptive guidance provided by the Microsoft Cloud Security Benchmark here: https://learn.microsoft.com/en-us/security/benchmark/azure/

Please note that while Benchmark prescriptive guidance does not yet exist for this service, there are likely considerations for secure configuration that may require your due care and due diligence. To determine which aspects of configuration are the responsibility of the customer, and which are assumed by Microsoft, we recommend reviewing Microsoft's Shared Responsibility Model: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

Help us improve this Benchmark! If you notice a needed correction, want to provide feedback, or wish to contribute security best practice guidance please join our community and create a ticket, propose a change, or start a discussion so we can improve this guidance!

The CIS Microsoft Azure Community is here: https://workbench.cisecurity.org/communities/72.

Resources for Azure Managed Instance for Apache Cassandra

Azure Product Page:

- https://azure.microsoft.com/en-us/products/managed-instance-apache-cassandra/

Azure Managed Instance for Apache Cassandra service overview:

- https://learn.microsoft.com/en-us/azure/azure-sql/virtual-machines/windows/sql-server-on-azure-vm-iaas-what-is-overview?view=azuresql&toc=%2Fazure%2Fvirtual-machines%2Fwindows%2Ftoc.json

Microsoft Cloud Security Baseline for Azure Managed Instance for Apache Cassandra:

- https://learn.microsoft.com/en-us/security/benchmark/azure/baselines/microsoft-azure-managed-instance-for-apache-cassandra-security-baseline

14 Azure Confidential Ledger (Reference)

Coverage Location:

- Benchmark: "CIS Microsoft Azure **Storage Services** Benchmark"
- Section: **Azure Confidential Ledger**

No prescriptive guidance exists yet for Azure Confidential Ledger. If you would like to contribute security best practice guidance for Azure Confidential Ledger, please join the CIS Microsoft Azure Community at https://workbench.cisecurity.org.

While this Service is under community development, we strongly recommend reviewing the relevant descriptive guidance provided by the Microsoft Cloud Security Benchmark here: https://learn.microsoft.com/en-us/security/benchmark/azure/

Please note that while Benchmark prescriptive guidance does not yet exist for this service, there are likely considerations for secure configuration that may require your due care and due diligence. To determine which aspects of configuration are the responsibility of the customer, and which are assumed by Microsoft, we recommend reviewing Microsoft's Shared Responsibility Model: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

---

Resources for Azure Confidential Ledger

Azure Product Page:

- https://azure.microsoft.com/en-us/products/azure-confidential-ledger/

Azure Confidential Ledger service overview:

- https://learn.microsoft.com/en-us/azure/confidential-ledger/overview

Azure Confidential Ledger vendor security recommendations:

- https://learn.microsoft.com/en-us/azure/confidential-ledger/secure-confidential-ledger

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**Introduction**		
1.1	**CIS Microsoft Azure Foundations Benchmarks**		
1.2	**CIS Microsoft Azure Service Category Benchmarks**		
1.3	**Multiple Methods of Audit and Remediation**		
1.4	**Automating with Azure Policy**		
2	**Azure Cache for Redis (Retiring)**		
2.1	Ensure 'Microsoft Entra Authentication' is 'Enabled' (Manual)	☐	☐
2.2	Ensure that 'Allow access only via SSL' is set to 'Yes' (Automated)	☐	☐
2.3	Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher) (Manual)	☐	☐
2.4	Ensure that 'Access Policies' are Implemented and Reviewed Periodically (Manual)	☐	☐
2.5	Ensure that 'System Assigned Managed Identity' is set to 'On' (Manual)	☐	☐
2.6	Ensure that 'Public Network Access' is 'Disabled' (Manual)	☐	☐
2.7	Ensure Azure Cache for Redis is Using a Private Link (Manual)	☐	☐
2.8	Ensure that Azure Cache for Redis is Using Customer-Managed Keys (Manual)	☐	☐
2.9	Ensure 'Access Keys Authentication' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.10	Ensure 'Update Channel' is set to 'Stable' (Automated)	☐	☐
3	**Azure Cosmos DB**		
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks (Automated)	☐	☐
3.2	Ensure that Cosmos DB uses Private Endpoints where possible (Automated)	☐	☐
3.3	Ensure that 'disableLocalAuth' is set to 'true' (Automated)	☐	☐
3.4	Ensure `Public Network Access` is `Disabled` (Manual)	☐	☐
3.5	Ensure critical data is encrypted with customer-managed keys (CMK) (Manual)	☐	☐
3.6	Ensure the firewall does not allow all network traffic (Automated)	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled (Manual)	☐	☐
4	**Azure Data Factory**		
4.1	Ensure Data Factory is encrypted using Customer Managed Keys (Manual)	☐	☐
4.2	Ensure Data Factory is using Managed Identities (Automated)	☐	☐
4.3	Ensure that Data Factory is using Azure Key Vault to store Credentials and Secrets (Manual)	☐	☐
4.4	Ensure that Data Factory is using RBAC to manage privilege assignment (Manual)	☐	☐
5	**Azure Database for MySQL**		
5.1	Ensure Azure Database for MySQL uses Customer Managed Keys for Encryption at Rest (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.2	Ensure Azure Database for MySQL uses only Microsoft Entra Authentication (Automated)	☐	☐
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL (Automated)	☐	☐
5.4	Ensure Private Endpoints Are Used for Azure MySQL Databases (Automated)	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server (Automated)	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server (Automated)	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server (Manual)	☐	☐
5.8	Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server (Automated)	☐	☐
5.9	Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server (Automated)	☐	☐
6	**Azure Database for PostgreSQL**		
6.1	Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest (Manual)	☐	☐
6.2	Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication (Manual)	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL (Automated)	☐	☐
6.4	Ensure Private Endpoints Are Used for Azure Database for PostgreSQL (Automated)	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.6	Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server (Automated)	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server (Automated)	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers (Automated)	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers (Automated)	☐	☐
6.10	Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server (Automated)	☐	☐
6.11	Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server (Automated)	☐	☐
7	**Azure Database Migration Service**		
8	**Azure SQL (Reference)**		
9	**Azure SQL Database**		
9.1	Ensure that 'Auditing' is set to 'On' (Automated)	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable' (Automated)	☐	☐
9.3	Ensure no Azure SQL Database firewall rule is overly permissive (Automated)	☐	☐
9.4	Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key (Automated)	☐	☐
9.5	Ensure that Microsoft Entra authentication is Configured for SQL Servers (Automated)	☐	☐
9.6	Ensure that 'Data encryption' is set to 'On' on a SQL Database (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
9.7	Ensure that 'Auditing' Retention is 'greater than 90 days' (Automated)	☐	☐
9.8	Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher (Automated)	☐	☐
10	**Azure SQL Managed Instance**		
11	**SQL Server on Azure Virtual Machines**		
12	**Table Storage (Reference)**		
13	**Azure Managed Instance for Apache Cassandra**		
14	**Azure Confidential Ledger (Reference)**		

Appendix: CIS Controls v7 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.6	Ensure that 'Public Network Access' is 'Disabled'	☐	☐
2.10	Ensure 'Update Channel' is set to 'Stable'	☐	☐
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks	☐	☐
3.4	Ensure `Public Network Access` is `Disabled`	☐	☐
3.6	Ensure the firewall does not allow all network traffic	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled	☐	☐
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable'	☐	☐
9.3	Ensure no Azure SQL Database firewall rule is overly permissive	☐	☐

Appendix: CIS Controls v7 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.1	Ensure 'Microsoft Entra Authentication' is 'Enabled'	☐	☐
2.2	Ensure that 'Allow access only via SSL' is set to 'Yes'	☐	☐
2.3	Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher)	☐	☐
2.6	Ensure that 'Public Network Access' is 'Disabled'	☐	☐
2.7	Ensure Azure Cache for Redis is Using a Private Link	☐	☐
2.9	Ensure 'Access Keys Authentication' is set to 'Disabled'	☐	☐
2.10	Ensure 'Update Channel' is set to 'Stable'	☐	☐
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks	☐	☐
3.2	Ensure that Cosmos DB uses Private Endpoints where possible	☐	☐
3.3	Ensure that 'disableLocalAuth' is set to 'true'	☐	☐
3.4	Ensure `Public Network Access` is `Disabled`	☐	☐
3.6	Ensure the firewall does not allow all network traffic	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled	☐	☐
5.2	Ensure Azure Database for MySQL uses only Microsoft Entra Authentication	☐	☐
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL	☐	☐
5.4	Ensure Private Endpoints Are Used for Azure MySQL Databases	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server	☐	☐
5.8	Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.9	Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server	☐	☐
6.2	Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL	☐	☐
6.4	Ensure Private Endpoints Are Used for Azure Database for PostgreSQL	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server	☐	☐
6.6	Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers	☐	☐
6.10	Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server	☐	☐
6.11	Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server	☐	☐
9.1	Ensure that 'Auditing' is set to 'On'	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable'	☐	☐
9.3	Ensure no Azure SQL Database firewall rule is overly permissive	☐	☐
9.4	Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key	☐	☐
9.5	Ensure that Microsoft Entra authentication is Configured for SQL Servers	☐	☐
9.7	Ensure that 'Auditing' Retention is 'greater than 90 days'	☐	☐
9.8	Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher	☐	☐

Appendix: CIS Controls v7 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.1	Ensure 'Microsoft Entra Authentication' is 'Enabled'	☐	☐
2.2	Ensure that 'Allow access only via SSL' is set to 'Yes'	☐	☐
2.3	Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher)	☐	☐
2.4	Ensure that 'Access Policies' are Implemented and Reviewed Periodically	☐	☐
2.6	Ensure that 'Public Network Access' is 'Disabled'	☐	☐
2.7	Ensure Azure Cache for Redis is Using a Private Link	☐	☐
2.8	Ensure that Azure Cache for Redis is Using Customer-Managed Keys	☐	☐
2.9	Ensure 'Access Keys Authentication' is set to 'Disabled'	☐	☐
2.10	Ensure 'Update Channel' is set to 'Stable'	☐	☐
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks	☐	☐
3.2	Ensure that Cosmos DB uses Private Endpoints where possible	☐	☐
3.3	Ensure that 'disableLocalAuth' is set to 'true'	☐	☐
3.4	Ensure `Public Network Access` is `Disabled`	☐	☐
3.5	Ensure critical data is encrypted with customer-managed keys (CMK)	☐	☐
3.6	Ensure the firewall does not allow all network traffic	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled	☐	☐
4.1	Ensure Data Factory is encrypted using Customer Managed Keys	☐	☐
5.1	Ensure Azure Database for MySQL uses Customer Managed Keys for Encryption at Rest	☐	☐
5.2	Ensure Azure Database for MySQL uses only Microsoft Entra Authentication	☐	☐
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.4	Ensure Private Endpoints Are Used for Azure MySQL Databases	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server	☐	☐
5.8	Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server	☐	☐
5.9	Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server	☐	☐
6.1	Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest	☐	☐
6.2	Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL	☐	☐
6.4	Ensure Private Endpoints Are Used for Azure Database for PostgreSQL	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server	☐	☐
6.6	Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers	☐	☐
6.10	Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server	☐	☐
6.11	Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server	☐	☐
9.1	Ensure that 'Auditing' is set to 'On'	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable'	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.3	Ensure no Azure SQL Database firewall rule is overly permissive	☐	☐
9.4	Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key	☐	☐
9.5	Ensure that Microsoft Entra authentication is Configured for SQL Servers	☐	☐
9.6	Ensure that 'Data encryption' is set to 'On' on a SQL Database	☐	☐
9.7	Ensure that 'Auditing' Retention is 'greater than 90 days'	☐	☐
9.8	Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher	☐	☐

Appendix: CIS Controls v7 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.5	Ensure that 'System Assigned Managed Identity' is set to 'On'	☐	☐
4.2	Ensure Data Factory is using Managed Identities	☐	☐
4.3	Ensure that Data Factory is using Azure Key Vault to store Credentials and Secrets	☐	☐
4.4	Ensure that Data Factory is using RBAC to manage privilege assignment	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.6	Ensure that 'Public Network Access' is 'Disabled'	☐	☐
2.10	Ensure 'Update Channel' is set to 'Stable'	☐	☐
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks	☐	☐
3.4	Ensure `Public Network Access` is `Disabled`	☐	☐
3.6	Ensure the firewall does not allow all network traffic	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled	☐	☐
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server	☐	☐
6.6	Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable'	☐	☐
9.3	Ensure no Azure SQL Database firewall rule is overly permissive	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.7	Ensure that 'Auditing' Retention is 'greater than 90 days'	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.1	Ensure 'Microsoft Entra Authentication' is 'Enabled'	☐	☐
2.2	Ensure that 'Allow access only via SSL' is set to 'Yes'	☐	☐
2.3	Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher)	☐	☐
2.5	Ensure that 'System Assigned Managed Identity' is set to 'On'	☐	☐
2.6	Ensure that 'Public Network Access' is 'Disabled'	☐	☐
2.7	Ensure Azure Cache for Redis is Using a Private Link	☐	☐
2.8	Ensure that Azure Cache for Redis is Using Customer-Managed Keys	☐	☐
2.9	Ensure 'Access Keys Authentication' is set to 'Disabled'	☐	☐
2.10	Ensure 'Update Channel' is set to 'Stable'	☐	☐
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks	☐	☐
3.2	Ensure that Cosmos DB uses Private Endpoints where possible	☐	☐
3.3	Ensure that 'disableLocalAuth' is set to 'true'	☐	☐
3.4	Ensure `Public Network Access` is `Disabled`	☐	☐
3.5	Ensure critical data is encrypted with customer-managed keys (CMK)	☐	☐
3.6	Ensure the firewall does not allow all network traffic	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled	☐	☐
4.1	Ensure Data Factory is encrypted using Customer Managed Keys	☐	☐
5.1	Ensure Azure Database for MySQL uses Customer Managed Keys for Encryption at Rest	☐	☐
5.2	Ensure Azure Database for MySQL uses only Microsoft Entra Authentication	☐	☐
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.4	Ensure Private Endpoints Are Used for Azure MySQL Databases	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server	☐	☐
5.8	Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server	☐	☐
5.9	Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server	☐	☐
6.1	Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest	☐	☐
6.2	Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL	☐	☐
6.4	Ensure Private Endpoints Are Used for Azure Database for PostgreSQL	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server	☐	☐
6.6	Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers	☐	☐
6.10	Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server	☐	☐
6.11	Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server	☐	☐
9.1	Ensure that 'Auditing' is set to 'On'	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable'	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.3	Ensure no Azure SQL Database firewall rule is overly permissive	☐	☐
9.4	Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key	☐	☐
9.5	Ensure that Microsoft Entra authentication is Configured for SQL Servers	☐	☐
9.6	Ensure that 'Data encryption' is set to 'On' on a SQL Database	☐	☐
9.7	Ensure that 'Auditing' Retention is 'greater than 90 days'	☐	☐
9.8	Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.1	Ensure 'Microsoft Entra Authentication' is 'Enabled'	☐	☐
2.2	Ensure that 'Allow access only via SSL' is set to 'Yes'	☐	☐
2.3	Ensure that 'Minimum TLS version' is set to TLS v1.2 (or higher)	☐	☐
2.4	Ensure that 'Access Policies' are Implemented and Reviewed Periodically	☐	☐
2.5	Ensure that 'System Assigned Managed Identity' is set to 'On'	☐	☐
2.6	Ensure that 'Public Network Access' is 'Disabled'	☐	☐
2.7	Ensure Azure Cache for Redis is Using a Private Link	☐	☐
2.8	Ensure that Azure Cache for Redis is Using Customer-Managed Keys	☐	☐
2.9	Ensure 'Access Keys Authentication' is set to 'Disabled'	☐	☐
2.10	Ensure 'Update Channel' is set to 'Stable'	☐	☐
3.1	Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks	☐	☐
3.2	Ensure that Cosmos DB uses Private Endpoints where possible	☐	☐
3.3	Ensure that 'disableLocalAuth' is set to 'true'	☐	☐
3.4	Ensure `Public Network Access` is `Disabled`	☐	☐
3.5	Ensure critical data is encrypted with customer-managed keys (CMK)	☐	☐
3.6	Ensure the firewall does not allow all network traffic	☐	☐
3.7	Ensure that Cosmos DB Logging is Enabled	☐	☐
4.1	Ensure Data Factory is encrypted using Customer Managed Keys	☐	☐
5.1	Ensure Azure Database for MySQL uses Customer Managed Keys for Encryption at Rest	☐	☐
5.2	Ensure Azure Database for MySQL uses only Microsoft Entra Authentication	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.3	Ensure `Public Network Access` is `Disabled` for Azure Database for MySQL	☐	☐
5.4	Ensure Private Endpoints Are Used for Azure MySQL Databases	☐	☐
5.5	Ensure server parameter 'audit_log_enabled' is set to 'ON' for MySQL flexible server	☐	☐
5.6	Ensure server parameter 'audit_log_events' has 'CONNECTION' set for MySQL flexible server	☐	☐
5.7	Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server	☐	☐
5.8	Ensure server parameter 'require_secure_transport' is set to 'ON' for MySQL Server	☐	☐
5.9	Ensure server parameter 'tls_version' is set to 'TLSv1.2' (or higher) for MySQL flexible server	☐	☐
6.1	Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest	☐	☐
6.2	Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication	☐	☐
6.3	Ensure `Public Network Access` is `Disabled` for Azure Database for PostgreSQL	☐	☐
6.4	Ensure Private Endpoints Are Used for Azure Database for PostgreSQL	☐	☐
6.5	Ensure server parameter 'connection_throttle.enable' is set to 'ON' for PostgreSQL server	☐	☐
6.6	Ensure server parameter 'logfiles.retention_days' is greater than 3 days for PostgreSQL server	☐	☐
6.7	Ensure server parameter 'log_checkpoints' is set to 'ON' for PostgreSQL server	☐	☐
6.8	Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers	☐	☐
6.9	Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers	☐	☐
6.10	Ensure server parameter 'require_secure_transport' is set to 'ON' for PostgreSQL server	☐	☐
6.11	Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL server	☐	☐

Recommendation		Set Correctly	
		Yes	No
9.1	Ensure that 'Auditing' is set to 'On'	☐	☐
9.2	Ensure that 'Public Network Access' is set to 'Disable'	☐	☐
9.3	Ensure no Azure SQL Database firewall rule is overly permissive	☐	☐
9.4	Ensure SQL server's Transparent Data Encryption (TDE) protector is encrypted with Customer-managed key	☐	☐
9.5	Ensure that Microsoft Entra authentication is Configured for SQL Servers	☐	☐
9.6	Ensure that 'Data encryption' is set to 'On' on a SQL Database	☐	☐
9.7	Ensure that 'Auditing' Retention is 'greater than 90 days'	☐	☐
9.8	Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
4.2	Ensure Data Factory is using Managed Identities	☐	☐
4.3	Ensure that Data Factory is using Azure Key Vault to store Credentials and Secrets	☐	☐
4.4	Ensure that Data Factory is using RBAC to manage privilege assignment	☐	☐

Appendix: Change History

Date	Version	Changes for this version
4-Dec-25	2.0.0	ADD - Azure Cache for Redis - Ensure Azure Cache for Redis is using a private link (Ticket 26343)
4-Dec-25	2.0.0	ADD - Azure Cache for Redis - Ensure 'Update Channel' is set to 'Stable' (Ticket 21804)
4-Dec-25	2.0.0	ADD - Azure Cache for Redis - Ensure 'Access Keys Authentication' is set to 'Disabled' (Ticket 26344)
18-Dec-25	2.0.0	ADD - Azure CosmosDB - Ensure `Public Network Access` is `Disabled` for Azure Cosmos DB (Ticket 26347)
17-Dec-25	2.0.0	ADD - Azure CosmosDB - Ensure critical data is encrypted with customer-managed keys (CMK) (Ticket 21820)
11-Dec-25	2.0.0	ADD - Azure CosmosDB - Ensure the firewall does not allow all requests from Azure (Ticket 26346)
29-Dec-25	2.0.0	ADD - Azure Data Factory - Encrypt Azure Data Factory With Customer Managed Keys (Ticket 21811)
18-Dec-25	2.0.0	ADD - Azure Data Factory - Ensure Managed Identities Are Configured (Ticket 26774)
29-Dec-25	2.0.0	ADD - Azure Data Factory - Ensure that Azure Key Vault is used to store credentials and secrets (Ticket 21808)
18-Dec-25	2.0.0	ADD - Azure Data Factory - Ensure that Azure RBAC is Used to Manage Privilege Assignment Within Data Factory (Ticket 21810)
18-Dec-25	2.0.0	ADD - Azure Database for MySQL - Ensure Private Endpoints Are Used for Azure MySQL Databases (Ticket 26352)
11-Dec-25	2.0.0	ADD - Azure Database for MySQL - Ensure `Public Network Access` is `Disabled` (Ticket 26473)

29-Dec-25	2.0.0	ADD - Azure Database for MySQL - Ensure Azure Database for MySQL uses only Microsoft Entra Authentication (Ticket 21742)
18-Dec-25	2.0.0	ADD - Azure Database for MySQL - Ensure Customer Managed Keys are Used for Encryption (Ticket 26472)
29-Dec-25	2.0.0	ADD - Azure Database for MySQL - Ensure server parameter 'error_server_log_file' is Enabled for MySQL Database Server (Ticket 21822)
30-Dec-25	2.0.0	ADD - Azure Database for PostgreSQL - Ensure Azure Database for PostgreSQL uses Customer Managed Keys for Encryption at Rest (Ticket 21823)
30-Dec-25	2.0.0	ADD - Azure Database for PostgreSQL - Ensure Azure Database for PostgreSQL uses only Microsoft Entra Authentication (Ticket 26804)
30-Dec-25	2.0.0	ADD - Azure Database for PostgreSQL - Ensure Private Endpoints Are Used for Azure Database for PostgreSQL (Ticket 26351)
29-Dec-25	2.0.0	ADD - Azure Database for PostgreSQL - Ensure server parameter 'ssl_min_protocol_version' is set to 'TLSv1.2' or higher for PostgreSQL flexible server (Ticket 26640)
30-Dec-25	2.0.0	ADD - Azure SQL Database - Ensure 'Minimum TLS Version' is set to 'TLS 1.2' or higher (Ticket 26407)
3-Nov-25	2.0.0	DELETE - Azure Database for MariaDB - Section Removed (Ticket 26470)
30-Dec-25	2.0.0	DELETE - Azure Database for PostgreSQL - Ensure 'Data encryption' for PostgreSQL servers is 'Enabled' (Ticket 22488)
14-Nov-25	2.0.0	UPDATE - Azure Confidential Ledger - Section Overview Updated (Ticket 26589)
3-Nov-25	2.0.0	UPDATE - Azure Cosmos DB - Section Overview updated (Ticket 26511)
22-Nov-25	2.0.0	UPDATE - Azure CosmosDB - Ensure that 'disableLocalAuth' is set to 'true' - Update Title, Assessment Status, add Audit and Remediation Procedure (Ticket 22427)

29-Dec-25	2.0.0	UPDATE - Azure CosmosDB - Ensure That 'Firewalls & Networks' Is Limited to Use Selected Networks Instead of All Networks - Some additional context/caveat message for access Cosmos DB Data Explorer (Ticket 21987)
3-Nov-25	2.0.0	UPDATE - Azure Data Factory - Section overview updated (Ticket 26512)
3-Nov-25	2.0.0	UPDATE - Azure Database for MySQL - Section Overview updated (Ticket 26513)
15-Dec-25	2.0.0	UPDATE - Azure Database for MySQL - Update all references of MySQL single server (Ticket 26476)
30-Dec-25	2.0.0	UPDATE - Azure Database for PostgreSQL - Change all mentions of PostgreSQL Single server to PostgreSQL flexible server (Ticket 26474)
30-Dec-25	2.0.0	UPDATE - Azure Database for PostgreSQL - Ensure server parameter 'log_connections' is set to 'ON' for PostgreSQL servers - Updated from Single Server to Flexible Server (Ticket 25233)
30-Dec-25	2.0.0	UPDATE - Azure Database for PostgreSQL - Ensure server parameter 'log_disconnections' is set to 'ON' for PostgreSQL servers - Remove references to Single Server (Ticket 25232)
3-Nov-25	2.0.0	UPDATE - Azure Database for PostgreSQL - Section overview updated (Ticket 26514)
3-Nov-25	2.0.0	UPDATE - Azure Database Migration Service - Section overview updated (Ticket 26515)
14-Nov-25	2.0.0	UPDATE - Azure Managed Instance for Apache Cassandra - Section Overview Updated (Ticket 26587)
14-Nov-25	2.0.0	UPDATE - Azure SQL (Reference) - Section Overview updated, SQL Edge Removed (Ticket 26584)
31-Dec-25	2.0.0	UPDATE - Azure SQL Database - Ensure no Azure SQL Database firewall rule is overly permissive - Renamed and rewritten to target evaluation of firewall rules with education on "Allow Azure services" exception (Ticket 24607)

30-Dec-25	2.0.0	UPDATE - Azure SQL Database - Ensure that 'Public Network Access' is set to 'Disable' - Update Title, Assessment Status, Profile Level, Impact, and add Audit and Remediation Procedure (Ticket 23890)
14-Nov-25	2.0.0	UPDATE - Azure SQL Database - Section Overview Updated (Ticket 26585)
14-Nov-25	2.0.0	UPDATE - Azure SQL Managed Instance - Section Overview Updated (Ticket 26586)
14-Nov-25	2.0.0	UPDATE - Benchmark Overview Updated - Added note about other DB services, Removed Maria DB, Removed SQL Edge (Ticket 26591)
3-Sep-24	2.0.0	UPDATE - Change Assessment Status from Manual to Automated - Assessment status changed from manual to automated (Ticket 22489)
3-Sep-24	2.0.0	UPDATE - Change Assessment Status from Manual to Automated - Assessment status changed from manual to automated (Ticket 22490)
14-Nov-25	2.0.0	UPDATE - SQL Server on Azure Virtual Machines - Section Overview Updated (Ticket 26588)
14-Nov-25	2.0.0	UPDATE - Table Storage (Reference) - Section Overview Updated (Ticket 26590)